Unveiling the Covert Vulnerabilities in Multi-Factor Authentication Protocols: A Systematic Review and Security Analysis

KOK WEE ANG*, Singapore University of Technology and Design, Singapore, Singapore
EYASU GETAHUN CHEKOLE*†, Singapore University of Technology and Design, Singapore, Singapore
JIANYING ZHOU, Singapore University of Technology and Design, Singapore, Singapore

Nowadays, cyberattacks are growing at an alarming rate, causing widespread havoc to the digital community. In particular, authentication attacks have become a dominant attack vector, allowing intruders to impersonate legitimate users and maliciously access resources. Traditional single-factor authentication (SFA) protocols, which rely on a single authentication factor are often insufficient to address the growing sophistication of modern cyberattacks. To address the shortcomings in SFA, multi-factor authentication (MFA) protocols have been widely adopted in recent years, raising the security bar against impostors and restricting unauthorized accesses. MFA enhances security by incorporating multiple authentication factors, such as knowledge-based (e.g., passwords), possession-based (e.g., tokens), and inherent-based factors (e.g., biometrics), among others. However, while MFA is generally considered more secure than SFA, it is not foolproof. Because, critical vulnerabilities may still arise due to design or implementation flaws in MFA protocols. These vulnerabilities are often overlooked by designers or users and remain undetected until exploited by attackers, potentially resulting in catastrophic consequences. Unfortunately, existing works failed to adequately analyze and identify most of such critical security flaws in MFA protocols. In this work, we systematically analyze the intricate design and construction of MFA protocols to uncover potential design-level security flaws. To this end, we first define eight security evaluation criteria that are essential to critically evaluate design-level security flaws of MFA protocols. These criteria are primarily derived from existing and newly introduced MFA security requirements. We then review a range of MFA protocols across various domains. Using our established evaluation criteria, we perform a systematic security analysis and evaluation of these protocols, particularly focusing on their design and construction. Ultimately, we uncover several security flaws in most of the MFA protocols evaluated. Due to space limitation, we select ten of those protocols for deeper security analysis and provide a detailed discussion of the respective flaws identified. Additionally, we devised relevant mitigation strategies for each of the flaws identified. We believe that our findings provide valuable insights to cybersecurity researchers and practitioners to help them addressing a wide range of security flaws in MFA protocols.

CCS Concepts: • **Security and privacy** → **Security protocols**.

Additional Key Words and Phrases: Multi-Factor Authentication, Authentication Factors, MFA Vulnerabilities, Mutual Authentication, Key Leakage Resilience, Perfect Forward Secrecy, User Anonymity

1 Introduction

The importance of information security has grown exponentially due to the dynamic and ever-evolving nature of cyber threats. Malicious adversaries frequently exploit security vulnerabilities to achieve unauthorized access,

*Both authors contributed equally and they share the first authorship.
†Corresponding author.

Authors' Contact Information: Kok Wee Ang, Singapore University of Technology and Design, Singapore, Singapore; e-mail: kok_ang@alumni.sutd.edu.sg; Eyasu Getahun Chekole, Singapore University of Technology and Design, Singapore, Singapore; e-mail: eyasu_chekole@sutd.edu.sg; Jianying Zhou, Singapore University of Technology and Design, Singapore, Singapore; e-mail: jianying_zhou@sutd.edu.sg.

Permission to make digital or hard copies of all or part of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for components of this work owned by others than the author(s) must be honored. Abstracting with credit is permitted. To copy otherwise, or republish, to post on servers or to redistribute to lists, requires prior specific permission and/or a fee. Request permissions from permissions@acm.org.
© 2025 Copyright held by the owner/author(s). Publication rights licensed to ACM.
ACM 1557-7341/2025/5-ART
https://doi.org/10.1145/3734864

Just Accepted

compromise sensitive data, or disrupt services. In particular, authentication-related attacks have emerged as a prominent concern in the cybersecurity landscape. These attacks often target weaknesses in authentication protocols, allowing them to impersonate legitimate users and gain unauthorized access to systems and services [53]. Consequently, implementing robust authentication mechanisms is crucial to mitigate cyber risks and protect systems from such attacks.

Traditionally, authentication protocols have relied on a single factor, such as passwords, PINs, pre-shared keys, or biometric identifiers. However, such single-factor authentication (SFA) is no longer adequate for addressing the complexities of modern cybersecurity challenges. Weak passwords, poor password management practices, and vulnerabilities to phishing attacks remain pervasive. For instance, users often choose easily guessable passwords or reuse them across multiple accounts, creating opportunities for attackers to compromise accounts [89]. Phishing attacks further exploit human vulnerabilities by tricking users into divulging authentication credentials through fraudulent emails or fake login pages [8]. Additionally, advanced techniques, such as side-channel attacks, brute-force methods or a combination of the two, enable adversaries to compromise even strong cryptographic keys. Even biometrics, widely regarded as a secure authentication factor, can be subject to spoofing or data breaches. These challenges necessitate the adoption of more robust authentication schemes, such as multi-factor authentication (MFA) [15].

MFA enhances security by incorporating multiple authentication factors, such as knowledge-based (e.g., passwords), possession-based (e.g., security tokens), inherent-based (e.g., biometrics), and location-based factors (e.g., GPS), among others. Despite its perceived robustness, MFA protocols are not also immune to vulnerabilities. In particular, flaws in the design, implementation, or integration of the authentication factors can undermine the intended security guarantees. Furthermore, complexities in the construction of MFA protocols – often involving diverse authentication factors, shared secrets, and public parameters – can obscure those design flaws. In fact, even rigorous formal security analyses have been shown to overlook such design flaws [83]. Consequently, such flaws are often left unnoticed by the protocol designers or end-users until they are exploited by attackers. Furthermore, while some protocols attempt to enhance the security of MFA protocols by over increasing the number of authentication factors, such approaches often impose significant performance overheads, making them unsuitable for resource-constrained devices.

In the literature, there are several reviews that have been conducted on MFA protocols. However, only a limited number of existing works have performed security analysis and evaluation of MFA protocols [11, 12, 43, 54, 57, 63, 75, 76, 81, 83]. Furthermore, these works primarily focus on a narrow range of security issues, leaving several critical vulnerabilities unexplored. Moreover, most existing works overlook design-level security flaws in MFA protocols. Therefore, this work bridges this gap by considering more critical MFA security requirements and identifying several design-level security flaws in these protocols.

To this end, we first defined our evaluation criteria for assessing the security of MFA protocols. Each criterion is linked to specific security threats, meaning that if an MFA protocol fails to satisfy a given criterion, it is deemed vulnerable to the corresponding threats. While there are a broad range of MFA security evaluation criteria available in the literature – such as password exposure, password/PIN strength, password-friendliness, usability, and unlinkability – most of these are typically used to evaluate application-level security issues, including social engineering, phishing, malware, physical attacks, insider threats, theft, guessing, privacy breaches, and service leaks [43, 83]. In this work, we defined eight evaluation criteria specifically tailored to critically assess and identify design-level security flaws in MFA protocols. These criteria are derived from a combination of existing MFA security requirements and newly introduced considerations. For example, some of the criteria, such as mutual authentication, perfect forward secrecy (PFS), user anonymity, and resilience to known attacks, are derived from existing MFA security requirements [42, 91]. The remaining criteria – distinctiveness of authentication factors, independence of authentication factors, (intermediary data or authentication factor) leakage resilience,

Just Accepted

and realistic adversarial assumptions – are either newly introduced in this work or have been overlooked in previous works.

Then, we conduct a comprehensive background study on authentication factors, which are the fundamental building blocks of MFA protocols. We categorize these factors into two primary groups: *conventional* and *emerging* authentication factors. Conventional factors include the well-established authentication factor categories, such as *knowledge factors* (e.g., passwords, PINs), *possession factors* (e.g., security tokens, smart cards), *inherent factors* (e.g., biometrics like fingerprints or iris scans), and *location factors* (e.g., GPS or IP-based authentication)[55]. Emerging factors, on the other hand, introduce new approaches, such as *historical data*, *physically unclonable functions (PUF)*, and *firmware integrity checks*[10, 23, 27]. This taxonomy is crucial for understanding how the synergy and independence of authentication factors impact the security of MFA protocols and the respective underlying systems.

Next, we conduct a literature review on several MFA protocols across various domains, as the security priorities vary from domain to domain. This includes MFA protocols in generic client-server systems [80], cloud computing [21], finance [39], healthcare [67], and Internet of Things (IoT) ecosystems [30]. Within IoT, we further explore subdomains, such as industrial IoT (IIoT)[45], healthcare IoT (HIoT) [88], WSN [48], and smart cities [61]. The primary inclusion criteria for selecting the protocols were their relevance (e.g., the proper use of two or more independent authentication factors), significance (e.g., publication in prominent cybersecurity journals or conferences), and recency (e.g., published between 2015 and 2025).

Using our established evaluation criteria, we carefully evaluated the security of several reviewed MFA protocols. Specifically, we analyzed the intricate details of their constructions to uncover weaknesses and flaws that could jeopardize the security of the authentication processes in the underlying systems. As a result, we identified critical security flaws in most of the evaluated protocols. However, due to space limitations, we selected only ten of these protocols for deeper security analysis and discussion. The selection criteria includes the availability of clear and detailed information about their design and construction (including the type and number of authentication factors used) and the presence of relevant design-level security flaws, particularly as per our evaluation criteria.

We then present a detailed analysis of the security flaws identified in each of the ten MFA protocols evaluated. Notably, many of these vulnerable protocols were published in prominent cybersecurity journals and conferences. However, these flaws remained undetected during the design, implementation, testing, and peer-review processes. Despite the rigorous formal and informal security analyses conducted in the original studies, these critical vulnerabilities were not identified. Additionally, we consolidate the runtime performance of the ten MFA protocols, offering additional insights into the trade-offs between security and efficiency that must be carefully considered when designing MFA protocols.

Finally, we devise relevant mitigation strategies to address each of the identified security flaws. Additionally, we discuss the potential challenges associated with implementing or applying these strategies and outline future research directions for each of the MFA security flaws identified.

In general, we believe that our findings provide valuable and practical insights to cybersecurity researchers and practitioners, helping them address a wide-range of security flaws in the design of MFA protocols. In general, this work makes the following key contributions:

- We present a comprehensive review of MFA protocols and authentication factors across various domains, offering a consolidated reference point for state-of-the-art MFA solutions.
- We establish a set of security evaluation criteria, incorporating both existing and newly introduced ones, to facilitate a design-level security analysis and evaluation of MFA protocols.
- Using the established evaluation criteria, we systematically evaluated several MFA protocols and uncovered critical security flaws in most of them. However, due to space constraints, we provide a deeper analysis and discussion on only ten of the vulnerable MFA protocols.

Just Accepted

- We devise mitigation strategies for the identified security flaws, discuss the potential challenges in their implementation, and outline future research directions, which help in the development of more secure and efficient MFA protocols in the future.

Organization. The remainder of this paper is organized as follows. Section 2 discusses the relevant related works. Section 3 offers background information on MFA and authentication factors. Section 4 provides a review of existing MFA protocols across different domains. Section 5 defines our adversarial assumptions and the MFA security evaluation criteria we employed. Section 6 presents a detailed account of our security analysis and evaluation on MFA protocols and discusses the security flaws identified. Section 7 discusses the proposed mitigation strategies to the security flaws identified, presents potential implementation challenges, and outlines future research directions. Finally, Section 8 concludes the paper by highlighting future research works. All the relevant acronyms and notations used in this paper are summarized in Table A.1.

2 Related works

Numerous reviews have been conducted on MFA protocols, covering various aspects of their design and functionality. However, only a small number of existing works have performed security analysis and evaluation on these protocols. In this section, we assess the most relevant related works based on our evaluation criteria presented in Section 5.2. We summarize their key contributions and highlight how our work compares and extends upon them.

In 2023, Wang and Wang [83] examined common pitfalls in the formal security proofs of MFA protocols, with a focus on protocols designed for mobile devices. They investigated the root causes of "provable security" failures in vulnerable MFA schemes under the random oracle model, classifying these failures into eight categories and illustrating them using three representative vulnerable MFA protocols. The authors further conducted a large-scale analysis of 70 representative MFA schemes using a set of evaluation criteria, including mutual authentication, forward secrecy, user anonymity, resistance to known attacks, password exposure, and sound repairability. Their findings highlighted that addressing failures in formal security proofs significantly improves the design of secure MFA protocols. Additionally, they offered recommendations for enhancing the robustness of future MFA designs. While their work provides valuable insights into the security evaluation of MFA protocols, it omits the critical MFA security requirements, such as the uniqueness of authentication factors, independence of authentication factors, leakage resilience, and realistic adversarial assumptions, outlined in Section 5.2.

In early 2025, Jubur et al. [43] conducted an in-depth security analysis of MFA protocols, with a particular focus on two-factor authentication (2FA) protocols. The authors assessed various 2FA protocols, including hardware token OTP, SMS OTP, software token and security key-based 2FA protocols across the usability, deployability, security, and privacy properties. With respect to security and privacy, they used several evaluation criteria, such as resilience to known attacks (e.g., impersonation, phishing, physical, insider, theft and guessing attacks), resilience to service leaks, and unlinkability (privacy), to evaluate several 2FA protocols. Their findings revealed several security flaws across different 2FA protocols. Nevertheless, this work did not cover many of the critical MFA security requirements presented in Section 5.2.

In 2023, Mahdad and Saxena [54] systematically evaluated and highlighted weaknesses of several 2FA protocols under the presence of concurrent session injection (CSI) attacks, where malware-infected terminals compromise authentication processes. In particular, they targeted two key vulnerabilities in the authentication system, namely "Malware on Terminal" and “Active Concurrent Attack", which refer to situations where an attacker is able to access user’s terminals and launch an attack in real-time. Ultimately, the authors assessed the security of 29 2FA protocols against CSI attacks. The result of their analysis revealed that almost all of the protocols are vulnerable to this attack. Although the authors discovered several 2FA protocols vulnerabilities against CSI attacks, they did not cover the critical MFA security requirements presented in Section 5.2.

Just Accepted

In 2023, Amft et al. [12] performed a wide-range of analysis and evaluation on the security and usability of MFA protocols. The authors first collected data from thousands of websites offering MFA protocols. Then, they performed an in-depth examination on the security and usability of the MFA recovery procedures deployed on these websites. Their findings revealed that many of the deployed MFA recovery procedures exhibit significant limitations both in terms of usability and security. However, this work primarily focuses on the usability and recovery issues of MFA protocols and it does not cover most of the critical MFA security requirements outlined in our evaluation criteria (cf. Section 5.2).

In 2024, Parier et al. [63] conducted a formal analysis and threat modeling on the security of MFA protocols, focusing in the context of digital identity card infrastructures. Using automated tools, such as ProVerif [20], they generated formal models to analyze and detect vulnerabilities in MFA protocols, and enumerate threat scenarios based on an attacker's capabilities. Their analysis revealed vulnerabilities that allow an attacker (e.g., phishing and malware attacks) to gain Level 2 authentication credentials using only Level 1 credentials. However, their work does not consider any of the critical MFA security requirements outlined in Section 5.2.

In 2020, Sinigaglia et al. [75] performed a latitudinal study and effectiveness of MFA protocols for online banking applications. In particular, the authors evaluated MFA protocols in terms of its compliance to banking regulations, security requirements, best practices, resistance to attacker models, and complexity and usability of employing them. In addition, the authors recognized that while implementing MFA systems for online banking can be challenging, the widespread adoption of MFA protocols that take the advantage of inheritance factors (i.e., biometric factors) could enhance both the security and efficiency of these systems. The authors also used certain evaluation criteria, such as the number of independent authentication factors to be employed in MFA protocols, in their evaluation. However, they did not consider the critical MFA security requirements presented in Section 5.2.

In 2023, Almadani et al. [11] assessed the effectiveness of blockchain-based MFA protocols. In particular, the authors assessed several MFA protocols using three evaluation criteria: 1) its ability to provide blockchain-based multi-factor authentication-as-a-service (BMFAaaS), 2) its ability to be universally accessible and highly responsive, and 3) its ability to integrate and import authentication credentials from other authentication platforms. Their analysis revealed that most of the MFA protocols assessed do not satisfy these evaluation criteria. However, their work does not cover any of the critical MFA security requirements presented in Section 5.2.

Suleski et al. [76] conducted an evaluation of MFA protocols within the HIoT domain. They began by addressing the security challenges and the necessity of MFA in HIoT, followed by a discussion of existing MFA solutions that are applicable in HIoT under different categories and circumstances. Then, they assessed the security of those MFA solutions, particularly their effectiveness against known attacks in healthcare services. Furthermore, they highlighted how these MFA solutions can be improved for better adoption and enhanced security in HIoT. However, their analysis overlooked many design-level security flaws of MFA protocols and failed to cover most of the critical security requirements outlined in Section 5.2.

In 2024, Venkatasubramanian et al. [81] evaluated MFA protocols, focusing on its effectiveness in defending cyberattacks. Specifically, the authors assessed the sensitivity, specificity, precision and accuracy of MFA protocols in stopping cyberattacks. Furthermore, the authors discussed the potential security risks of using MFA protocols and highlight satisfactory implementation practices to be followed to enhance the effectiveness of these protocols. However, this work does not consider any of the critical MFA security requirements outlined in Section 5.2.

In 2023, Mohammed et al. [57] conducted a security analysis on MFA protocols, by classifying them into biometric and non-biometric based approaches. The authors discussed the security and performance issues manifested in both biometric and non-biometric MFA protocols. In addition, they highlighted the unique characteristics and challenges exhibited in both MFA categories. However, this work did not cover the critical security requirements we outlined in Section 5.2.

Just Accepted

In 2021, Jacomme and Kremer [41] designed a comprehensive threat model for MFA protocols, considering factors such as TLS-secured communications, malware infections, phishing attacks, and human errors. The model is formalized using the applied pi calculus and perform an extensive analysis and comparison of several widely used MFA protocols, including Google 2-step verification and FIDO's U2F. The automated analysis systematically explores all possible threat scenarios, revealing both weaknesses and strengths of these protocols. The authors validate their findings through practical experiments in a controlled lab setting. However, this work does not cover most of the MFA critical security requirements as outlined in Section 5.2.

Gilsenan et al. [37] systematically assesses the backup and recovery features of MFA protocols. In particular, this work analyzes the backup methods of time-based one-time password (TOTP) 2FA apps. It analyzes analyzing 22 general-purpose Android apps that uses TOTP as a second authentication factor. Findings of the analysis revealed that most backup methods of the apps rely on the same insecure technologies – passwords, SMS, and email – that TOTP 2FA was designed to replace. Additionally, many implementations expose user data to third parties, suffer from cryptographic weaknesses, or allow developers to access TOTP secrets in plaintext. While this work provides insights on the security of backup methods, it does not cover the critical security issues in MFA.

Overall, while existing works have performed different types of analyses and evaluations on MFA protocols, they failed to address most of the critical MFA security requirements presented in Section 5.2. A qualitative comparison (e.g., based on the coverage of critical MFA security requirements or the evaluation criteria outlined in Section 5.2) and a quantitative comparison (e.g., based on the number and severity of vulnerabilities identified) of these related works is presented in Table 1.

3 Background

3.1 Overview of MFA

MFA is employed in diverse contexts to ensure secure access to systems, applications, or sensitive information. It strengthens security measures by requiring individuals or entities to provide multiple authentication factors that prove their identity before they are allowed to access the system or application. This approach goes beyond traditional SFA and adds additional layers of security by combining multiple authentication factors.

As highlighted in the introduction, the reliance on a single authentication factor, such as passwords, PINs, secret keys, and biometrics, is no longer sufficient for the current security trends and requirements. So, by reducing the dependence on a single authentication factor, MFA can impose stronger verification mechanisms. Even if one of the factors is compromised, the inclusion of additional factors in MFA prevents attackers from advancing without presenting the complete set of authentication factors. It is worth noting that MFA is nowadays commonly required in regulatory standards [1, 40] and recommended in advisories [2, 3] to safeguard the security of systems and sensitive information.

3.2 Authentication factors

Authentication factors are the building blocks of MFA protocols. They are combined systematically to form an MFA protocol with adequate security guarantees. In this work, we classify them into conventional and emerging categories. These categories and their respective subcategories are discussed in detail below and illustrated in Figure 1 with examples.

3.2.1 Conventional authentication factors. This category consists of the four types of authentication factors that are commonly used in MFA protocols. It includes knowledge factors, possession factors, inherent factors, and location factors [86].

[§]Estimated by correlating the vulnerability detected with a relevant CVSS metrics. https://nvd.nist.gov/vuln-metrics/cvss.

Just Accepted

Table 1. Qualitative and quantitative comparison of related works

Related work	Evaluation Criteria								Other criteria used?	Number of flaws identified	Severity of flows
	EC1	EC2	EC3	EC4	EC5	EC6	EC7	EC8			
Wang and Wang [83]	✓	×	×	✓̸	✓	✓	✓	×	Password friendly, sound repairability	NI	NI
Jubur et al. [43]	×	×	×	✓̸	×	✓	✓	×	Unlinkability, usability, deployability	$5\times EC4+7\times EC6+10\times EC7+10\times OC=32$	High§
Mahdad and Saxena [54]	✓̸	×	×	✓̸	×	×	✓̸	×	Resilience against CSI attack	$29\times OC$	High§
Amft et al. [12]	✓	×	×	×	×	×	×	×	MFA recovery procedures	NI	NI
Parier et al. [63]	×	×	×	×	×	×	✓̸	×		$11\times OC$	Medium§
Sinigaglia et al. [75]	×	×	✓̸	×	×	×	✓̸	×	Banking regulations	NI	NI
Almadani et al. [11]	×	×	×	×	×	×	×	×	BMFAaaS, cross-platform credentials	NI	NI
Suleski et al. [76]	×	×	×	×	×	✓	✓	×	Adoption of MFA in IoTH	NI	NI
Venkatasubramanian et al. [81]	×	×	×	×	×	×	✓̸	×	Sensitivity, precision, accuracy	NI	NI
Mohammed et al. [57]	×	×	×	×	×	×	✓	×		NI	NI
Jacomme and Kremer [41]	×	×	×	✓̸	×	✓̸	✓	×	Phishing, fingerprint spoofing	NI	NI
Gilsenan et al. [37]	×	×	×	✓̸	×	×	✓̸	×	Security of MFA backup methods	NI	NI
Ours	✓	✓	✓	✓	✓	✓	✓	✓		$5\times EC1+4\times EC2+6\times EC3+10\times EC4+9\times EC5+6\times EC6+8\times EC7+9\times EC8=57$	High

Description of notations: EC1: Mutual Authentication, EC2: Distinctiveness of Authentication Factors, EC3: Independence of Authentication Factors, EC4: Leakage Resilience, EC5: Perfect Forward Secrecy, EC6: User Anonymity, EC7: Resilience Against Known Attacks, EC8: Adversarial Assumption, OC: Other Criteria, NI: No Information, ✓: Covered, ✓̸: Partially Covered, ×: Not Covered, *: Estimated

Knowledge factors. Knowledge factors refer to something the individual knows, such as a password, PIN, or security questions. It is widely employed to verify an individual's identity and grant access to systems. Knowledge factors are based on the assumption that the individual is solely the one who knows the information. However,

Just Accepted

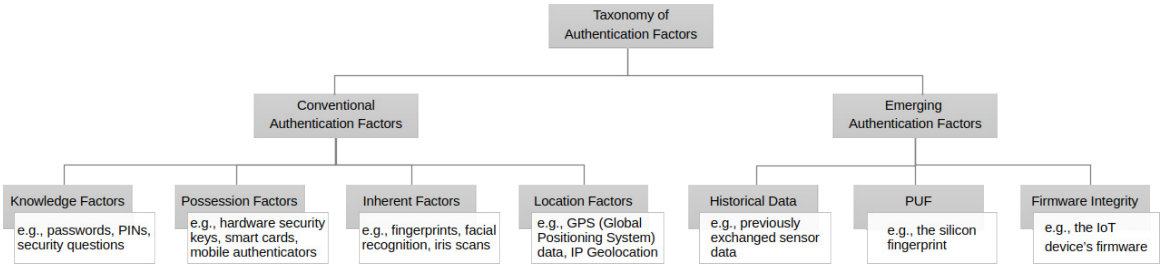

Fig. 1. Taxonomy of authentication factors

knowledge factors may potentially be susceptible to known attacks. As highlighted in earlier, passwords can be weak or easily guessed. Security questions can sometimes have answers that can be easily obtained or guessed [65].

Possession factors. Possession factors involve something the individual possesses. A typical example of a possession factor is a physical token, such as a hardware security key or a smart card. Using such tokens, cryptographic algorithms are typically utilized to generate a unique code or response to verify the user's identity. Mobile authenticators are another form of a possession factor. They are applications installed on an individual's mobile device. Mobile authenticators employ algorithms such as HMAC-based One-Time Password (HOTP) or Time-based One-Time Password (TOTP) to generate a One-Time Password (OTP) at regular intervals. The individual is required to enter the generated OTP to verify their identity.

Inherent factors. Inherent factors rely on something the individual is or has, typically related to an individual's biological traits or physical characteristics. These traits are difficult to replicate and provide an elevated level of security [6]. Fingerprints, facial recognition, and iris scans are examples of inherent factors.

These inherent factors offer several advantages in authentication. They provide high accuracy and security since they are difficult to counterfeit or manipulate. Additionally, they eliminate the need for users to remember passwords or carry physical tokens, enhancing convenience and user experience.

Location factors. The use of location as an additional authentication factor has been introduced recently [55]. This factor considers the individual's physical presence and compares it to their expected or usual location. If the user's location deviates significantly from their regular pattern or appears suspicious, it can trigger additional verification steps. The prevalence of mobile devices and technological advancements like global positioning system (GPS) [78], IP geolocation [70], and proximity authentication through ambient sounds [44] have led to the increased prominence of location-based authentication.

3.2.2 Emerging authentication factors. The conventional authentication factors discussed in Section 3.2.2 above possess certain limitations, especially when employed for machine-to-machine (M2M) authentications. Hence, they pose a challenge in ensuring secure M2M communications and transactions. Machines, unlike humans, cannot produce and provide certain authentication factors, such as password or biometric data. New types of authentication factors, such as historical data, PUF and firmware integrity, are emerged to address these issues.

Historical data. Historical data [23] (e.g., previously exchanged sensor data between a client and server) is recently introduced as a strong authentication factor due to its dynamic nature and high leakage resilience. It is incorporated by selecting a set of indices from the historical dataset that is continuously expanding and using the corresponding data and tags to compute the response as part of the authentication process. As historical data is

Just Accepted

constantly expanding (even if an adversary compromises the data), it will get outdated soon after, leaving limited room for exploitation.

Physically unclonable functions (PUF). PUF [10, 34] utilizes the physical distinction of each electronic device to generate a unique response when provided with a challenge. These distinctions are typically introduced during the manufacturing processes. Given the difficulty in replicating the same response, PUF is used as an authentication factor. While there may be slight variation in the response due to external factors, it can be rectified using fuzzy extractors.

Firmware integrity. Firmware integrity [27] utilizes the IoT device's firmware to verify its integrity and authenticity. Unlike traditional computing devices, most IoT devices have firmware as their operating system and interact directly with the hardware to complete the required assignments. With technological advancement, some IoT devices are installed with embedded operating systems (OS) such as Windows CE, embedded Linux OS, etc., where the image files are typically stored together with other essential files in a flash or embedded multi-media card. Any unauthorized modification would affect the integrity of the stored content, simplifying the authenticity checks of the IoT device by verifying the firmware integrity.

4 Literature review on MFA protocols

Before delving into our deeper security analysis of the selected MFA protocols in Section 6, we provide a summary of the literature reviews conducted on various MFA protocols. The literature review is essential for gaining a deeper understanding of the current trends and advancements in MFA security. Given the multitude of MFA protocols available, it is important to understand the approaches undertaken by researchers when designing the MFA protocols.

4.1 Selection criteria

In recent years, extensive research and development efforts have resulted in the development of numerous MFA protocols across various domains, including but not limited to cloud computing, finance, healthcare, and the rapidly growing fields of IoT, which can be further categorized as generic IoT, IIoT, HIoT, WSN and smart cities. To uncover vulnerabilities in MFA protocols, we began by reviewing several research papers spanning these domains. Our primary inclusion criteria were: (1) relevance of the work (e.g., properly employed two or more authentication factors), publication status (i.e., pear-reviewed papers published in reputable cybersecurity conferences or journals), and publication time (published between 2015 and 2025). Papers that are non-peer-reviewed or published in non-English languages are excluded.

Furthermore, although most of the reviewed protocols exhibit security flaws, we select ten of them for a deeper security analysis and discussion (as detailed in Section 6) due to space limitation. Our selection criteria were: (1) the availability of clear and detailed information about the design and construction of the authentication process (including the type and number of authentication factors employed) and (2) the presence of relevant design-level security flaws, particularly based on our established evaluation criteria outlined in Section 5.2. Below, we provide an overview of some of the reviewed protocols selected from various domains.

4.2 Generic client-server architecture

Ertan et al. [80] designed a two-factor authentication protocol for a generic client-server architecture. It uses TOTP and PUF as the first and second authentication factors to alleviate the security posture of TOTP systems. The MFA protocol uses PUF as storage to securely store the client's secret. This work assumed that Transport Layer Security (TLS) is in place to secure the communication channel between the entities.

Just Accepted

Ivaylo Chenchev [28] proposed an MFA protocol secure communications in a client-server or peer-to-peer architecture. The protocol uses time-based one-time passwords (TOTP) and dynamically generated passwords (which is not stored anywhere) as authentication factors. This protocol mainly intended to address the vulnerabilities of traditional password-based MFA protocols that potentially arise due to insecure generation of passwords.

Chen et al. [25] proposed a biometrics-based three-factor authentication and key agreement scheme for multi-server environments. This work mainly focused on addressing the weakness of conventional MFA protocols when adopted in a multi-server environment. This protocol employs a user id, a password and a digital signature as authentication factors. This work claimed to achieve resilience against several impersonation and reply attacks.

4.3 Cloud computing

As the adoption of cloud computing continues to grow, there is a corresponding rise in adversaries targeting cloud services. MFA improves the robustness and efficiency of the authentication process, thereby enhancing the overall security posture of cloud-based systems and safeguarding sensitive data from potential cyber threats.

Bouchaala et al. [21] proposed a cloud-based MFA protocol using a user id and a password, and additionally, smart card as authentication factors. This protocol is based on elliptic curve cryptography (ECC) and consists of four phases that include registration, authentication, key update, and card revocation. The key update phase facilitates the renewal of cryptographic keys stored in the smart card to maintain security, while the card revocation feature allows for the immediate revocation of compromised or lost smart card to reduce the likelihood of security compromise. Through the formal and informal security analysis conducted, it is claimed that this protocol is able to prevent various types of attacks.

Lee et al. [50] proposed a three-factor MFA protocol specifically designed for the cloud environment. This protocol employs a password, a smart device, and biometric data as authentication factors. It consists of four main phases: registration, login and authentication, password change, and identity update. The protocol allows users to update their passwords and modify personal information as required. It is claimed that the protocol achieves mutual authentication and establishes a secure communication channel between the involved entities.

Lee et al. [90] proposed an innovative and improved three-factor authentication protocol to mitigate known attacks, such as replay, offline guessing and denial-of-service (DoS) attacks. Besides a password and biometric data as the first and second authentication factors, the protocol allows the flexibility of using a laptop and/or smart card as the third authentication factor. Users can still complete the authentication process if the laptop or smart card is lost. The protocol consists of a registration and authentication phases.

Google developed Google Authenticator [77] to provide its users with an additional layer of security. With the enhancement, besides furnishing their username and password, users are required to furnish the OTP generated by the Google Authenticator registered to their account as the second authentication factor to verify their identity when accessing Google services. Any other services or applications that support TOTP algorithm can also utilize Google Authenticator as the second authentication factor.

4.4 Finance

MFA is also widely adopted by the financial sectors, such as banks, insurance companies, and various payment systems, to securely authenticate individuals before allowing them to perform any financial transactions. Scam and fraud transactions, and privacy of clients are some of the critical security concerns in this domain.

Hassan and Shukur [39] proposed a three-factor authentication protocol to enhance the authentication process for an electronic payment system. It combines three authentication factors: a password, biometric, and OTP. The protocol consists of three phases: registration, authentication and transaction phases, to safeguard the payment system against a wide range of attacks.

Just Accepted

Durairaj and Ramachandran [33] proposed an innovative approach to their ECC-based authentication protocol. In addition to low entropy password, international mobile subscriber identity (IMSI) of the user's device, and fingerprint, Durairaj and Ramachandran proposed to include the feature extracted from voice print, processed using mel frequency cepstral coefficient (MFCC) algorithm as an additional authentication factor. A proof is provided as this MFA protocol is able to establish secure communication channels between two entities after a successful mutual authentication.

Similarly, Abiew et al. [4] also adopted an innovative low-cost approach using another authentication factor, namely keystroke dynamics, to improve the authentication process. Through the experiment conducted, it is proved that this protocol is able to mitigate the vulnerability of ATM PINS to dictionary attacks.

Aburbeian et al. [5] proposed a protocol that integrates MFA and machine learning to secure financial transactions. The protocol involves two stages security. In the first stage, the protocol employs fingerprint and OTP as authentication factors to authenticate users. In the second stage, the protocol involves a machine learning layer, which employs facial recognition as a decisive and third authentication factor. This is to further enhance the security and robustness of the authentication process. It is claimed as this protocol has achieved several security features with high accuracy.

4.5 Healthcare

In healthcare, researchers have focused on developing MFA protocols particularly designed to protect lost of patient data, privacy breaches and unauthorized access to health-related information.

Sabeeh and Yassin [67] proposed a two-factor authentication protocol to authenticate the administrator in the healthcare system using a password and an SMS token as authentication factors. The components include an administrator, user data entry, and a healthcare center and are based on typical authentication phases such as initialization, registration, and authentication phase. Scyther tool was utilized to assess the security properties of the MFA protocol and proved to be capable of resisting known attacks.

Shamshad et al. [71] proposed an improved ECC-based two-factor authentication protocol that employs a password and a smart card as authentication factors to enhance the authentication process. Besides the typical registration and authentication phases, the protocol includes a password change phase to facilitate the change of password when required. While the performance of the protocol was observed to be sub-optimal, it is proved that it can resist various known attacks with high accuracy.

Ali et al. [9] identified several vulnerabilities in the protocol proposed by Barman et al. [19], including susceptibility to session key leakage, server impersonation, and user impersonation attacks. To address these security flaws, Ali et al. [9] introduced an improved three-factor MFA protocol. This protocol utilizes a password, a smart card, and biometric data as its authentication factors. Additionally, it incorporates a user revocation feature, enabling user accounts to be revoked in cases such as smart card loss. The proposed protocol claimed to achieve several security properties, including resilience against key leakage attacks, impersonation attacks, and other known threats.

Dhillon et al. [32] proposed a three-factor authentication protocol (involving a password, biometric data, and a smart card as its authentication factors) to establish a secure communication channel between a medical professional and a cloud server. The informal and formal security analysis of this work demonstrated that the proposed MFA protocol is capable of resisting various known attacks.

4.6 IoT

The rapid proliferation of IoT devices has contributed to the surge in designed MFA protocols. The authentication process for IoT devices is unique due to resource-limited devices and M2M communication scenarios where human involvement is minimal or absent. That poses challenges for traditional authentication factors like

Just Accepted

PINs, passwords, and biometrics. Within the IoT domain, there are subdomains, such as generic IoT, IIoT, HIoT, smart cities/homes, and WSN, that may require specifically tailored MFA protocols to address their respective requirements and challenges.

4.6.1 Generic IoT. Cvetković et al. [30] presented on the application of MFA protocols in the context of generic IoT. With the complexity of IoT architecture taken into consideration, the paper briefly discussed the various IoT security techniques that stood out, the security objectives of IoT, selected MFA protocols relevant to IoT, and security considerations specific to MFA implementation in the IoT. The findings presented in the paper contribute to understanding MFA protocols suitable for IoT environments and provide insights into the challenges and considerations involved. With the limitations faced, this work highlighted the need for efficient resource utilization, lightweight security authentication protocols, and cryptographic algorithms customized for the IoT environments.

Chen et al. [27] introduced a new authentication protocol designed specifically to enhance the security of IoT devices through MFA. This protocol incorporates a hierarchical architecture based on the traditional IoT system, comprising the perception, network, and application layers. In addition to a secret cryptographic key and PUF, the integrity of the device's firmware, which is used to ensure integrity, is also employed as one of the authentication factors. The protocol also supports firmware updates, enabling the deployment of patches and security enhancements.

Mirsaraei et al. [36] proposed an ECC-based MFA protocol on a blockchain platform for generic IoT devices. It employs a password, biometric data, and a smart card as the authentication factors. In addition to the typical registration phase, login phase, and authentication phase, an update phase was included to facilitate password and biometric information updates. Through the informal and formal security analysis, it is proved that this protocol satisfies the typical security requirements in IoT and is capable of resisting known attacks. Automated validation of Internet security protocols and applications (AVISPA) tool was utilized to automate the formal security analysis of this protocol.

Zahednejad et al. [91] proposed a two-factor authentication protocol for generic IoT devices in an M2M context. The protocol employs a long-term cryptographic key and data items as authentication factors. The three phases include initialization, authentication, and a revocation phase to revoke compromised or lost devices. To simulate real-life scenarios, this work assumed a strong adversary capable of compromising the server and retrieving all the information within and proved that the MFA protocol was able to ensure a secure authentication process and repel attacks.

Sadhukhan et al. [68] proposed an ECC-based lightweight three-factor authentication protocol (involving a user identity, a password and biometric data as the authentication factors) for authenticating remote users in IoT network. This work performed formal and informal security analysis to demonstrate that the protocol achieves several security features, such as resilience against impersonation and DoS attacks, perfect forward secrecy (PFS), and user anonymity, among others.

Melki et al. [56] proposed a lightweight ECC-based two-factor authentication protocol to provide secure communication channels between an IoT device and a gateway. A secret session identifier ID_s (that is derived from a PUF output value) and a secret channel-based parameter σ_i are used as authentication factors. This work claimed to have achieved several security features, such as PFS, session secrecy, user privacy, and resilience against reply, side-channel and man-in-the-middle attacks.

4.6.2 IIoT. A wide range of IIoT-based MFA protocols has been proposed over the years [42, 45, 52, 82]. Sain et al. [69] provided an overview of security issues related to CPS and explored the use of MFA to improve security. This work also discussed the evolution of authentication, elaborated on the importance of MFA, and highlighted the rapid adoption of biometrics as one of the authentication factors. MFA protocols designed for CPS were deliberated and compared against an established set of evaluation criteria.

Just Accepted

Khalid et al. [45] introduced an MFA protocol designed for cross-platform IIoT systems. This protocol combines a password, a smart card, and biometric data as authentication factors to enhance the authentication process cross-platform IIoT systems. It utilizes the AES-ECC algorithm to secure communications between the entities. The protocol encompasses various phases, including setup, user and fog node registration, login, and authentication, ensuring only access to authenticated users. The BAN logic was employed to perform a formal security analysis to prove the security of this protocol.

Vinoth et a. [82] proposed a three-factor authentication protocol for IIoT. It employs a combination of authentication factors, including a password, a smart card, and biometric data, to establish secure communication channels in the IIoT domain. The protocol consists of seven phases: offline sensing device and user registrations, login, authenticated key agreement, biometric and password update, and dynamically sensing device addition and revocation. The security of this MFA protocol was proven using the ROR model.

Li et al. [52] proposed a low-interactivity multi-factor authenticated key exchange (MAKE) protocol, called the "Secure Remote Multi-Factor Protocol," designed to enhance the security of M2M communication within the IIoT. The protocol strengthens the authentication process by employing multiple authentication factors, including a password, biometric data, and OTP. The security of the key exchange process was formally proven using the Bellare-Pointcheval-Rogaway (BPR) model.

Jin et al. [42] proposed a historical data-based multi-factor authenticated and confidential channel establishment (HMACCE) protocol for the M2M communication within the IIoT. This protocol involves a client and a server as the entities, with the client possessing a long-term symmetric key and a secret key as authentication factors. In contrast, the server holds a long-term symmetric key, historical data, and data tags. The protocol encompasses three phases, including initialization, tag generation, and online authentication and key exchange. During the tag generation phase, authentication tags are generated using the historical data and data tags, enabling subsequent verifications. This work also includes another HMACCE protocol named π_{FS} to address the issue of adaptive bounded leakage.

Han et al. [38] proposed a a three-factor MFA and key agreement protocol to secure the communication in IIoT that specifically involves three entities, namely user, gateway and sensing device. The protocol employs a user id, a password and a biometric key (that is generated from the users biometric data using a fuzzy extractor) as authentication factors. The protocol is mainly designed to address the vulnerabilities of a prior work [66], such as lack of forward security, and vulnerability to insider attack and known session-specific temporary information (KSSTI) attack.

4.6.3 HIoT. Jia et al. [88] proposed a two-factor authentication protocol for a fog-driven IoT healthcare system using a password and a smart card as authentication factors. This protocol designed is specifically for healthcare applications in the IoT domain. It involves several phases, including system setup, registration of users and fog nodes, authentication, and key agreement. In addition, password updates, user revocation and re-registration, and fog node revocation were also included to ensure comprehensiveness. The bilinear pairing was utilized to compute cryptographic operations efficiently. Formal and informal security analyzes against known attacks were also performed to demonstrate the security of this protocol.

Al-Saggaf et al. [7] introduced an innovative and improved two-factor authentication protocol specifically designed for the IoT-enabled healthcare ecosystem. The protocol combines a smart card and biometric data as authentication factors. Given the challenges in post-quantum computing, this work utilized a post-quantum fuzzy commitment (PQFC) scheme to protect the biometric template. It consists of several key phases, including setup, registration, login, authentication, and biometric revocation. By incorporating biometric revocation capabilities, the use of suspected compromised biometrics is prevented.

Azrour et al. [14] designed a two-factor authentication protocol to address the vulnerabilities observed in a prior work [72]. This protocol employs a password and a smart card as authentication factors to secure communications

Just Accepted

between healthcare systems in the cloud IoT. It encompasses several phases, including system setup, registration of new sensors and users, login and authentication, and password update. Formal security analysis was performed using the Scyther tool and the ROM model, in addition to informal security analysis to verify the security of this MFA protocol.

Chen et al. [26] proposed a privacy-preserving three-factor MFA scheme to secure a cloud-assisted medical IoT. The protocol employs a user id, a password and biometric data as the authentication factors. This work claimed to have achieved several security properties, such as post-quantum security, PFS, user anonymity, and resilience against reply and impersonation attacks.

4.6.4 WSN. Lee et al. [51] proposed a three-factor authentication protocol specifically designed for WSN. It consists of three phases, including registration of users and sensors phase, login and authentication phase, and password change phase. It employs a password, biometric data, and a smart card as authentication factors. All users and sensors must register with the gateway before establishing any connection. The protocol utilizes "honey list" and "fuzzy extractor" techniques to enhance security . ProVerif tool was employed to prove the security of this protocol. Its performance was also proved to be exceptionally better as compared to other related MFA protocols.

Kumar et al. [47] proposed a three-factor authentication protocol incorporating a password, a smart card, and biometric data as authentication factors. This protocol involves several phases, including the initialization base station phase, user and sensor node registration phase, login and authentication phase, and password and session key updating phase, into the protocol design where users can update their password and generate new session keys for enhanced security. The protocol also allowed the inclusion of new sensor nodes into the network with proper authentication procedures through the adding new nodes phase. The ROR model and the AVISPA tool were employed to demonstrate the security of the MFA protocol, which proved to satisfy the security requirements.

Wang and Wang [83] aimed to investigate and understand the failures observed in the security proofs of MFA protocols specifically designed for mobile devices. The paper provided an overview of MFA protocols designed for mobile devices, an understanding of security proofs failures in MFA protocols, the development of an enhanced set of evaluation criteria, and an analysis of a selection of ten MFA protocols. This work also proved that protocols with formal security proofs were able to better satisfy the established evaluation criteria which aid in the design of a more secure MFA protocol for mobile devices.

4.6.5 Smart cities/homes. The two-factor authentication protocol for smart cities proposed in [61] incorporates a password and a smart card as authentication factors. The protocol consists of several phases, including setup, user and sensors registration phase, login phase, authentication and key exchange phase, update phase, and revocation phase to allow for the removal of user privileges if necessary. Besides informal security analysis using BAN logic, which was typically used for formal security analysis, AVISPA tool was employed to prove the security of the MFA protocols. A comparison with other related MFA protocols was also conducted to demonstrate its effectiveness.

Wang et al. [84] designed an improved ECC-based three-factor authentication protocol based on ECC for smart homes using a password, a smart card, and biometric data as authentication factors. The initialization, registration, login and authentication, and password update phase were involved in the authentication process. The security of this MFA protocol was demonstrated through formal security analysis using BAN logic and demonstrated its efficiency through performance comparison with other related MFA protocols.

Oh et al. [59] proposed a two-factor authentication protocol, designed to address the security issues observed in an earlier work [87]. It employs a password and a mobile device as authentication factors. The protocol involves a series of phases, from initialization and device registration to authentication and key agreement processes. The protocol also supports password updates for enhanced security. Secure communication and interaction between the Mobile User and the Smart Device are established through the Home Gateway. A combination of

Just Accepted

tools, including BAN logic, ROR model, and AVISPA tool, was utilized to demonstrate the security of the MFA protocol.

4.7 Mobile authenticators

Recently, mobile applications are widely used as authentication factors in most of the domains mentioned above. For example, Google developed Google Authenticator to provide its users with an additional layer of security [77]. With the enhancement, besides furnishing their username and password, users are required to furnish the OTP generated by the Google Authenticator registered to their account as the second authentication factor to verify their identity when accessing Google services. Any other services or applications that support the TOTP algorithm can also use Google Authenticator as the second authentication factor.

However, such authenticators are also not without security risks. In a recent publication [62], researchers discovered vulnerabilities in several mobile authenticators that exposed the unique secret key. The affected authenticators (as illustrated in Figure 2) includes Epic Authenticator, Google Authenticator, Microsoft Authenticator, Sophos Authenticator, Red Hat Free OTP, and Twilio Authy Authenticator. These vulnerabilities allowed an adversary to access the unique secret key stored plainly at specific repository locations, such as directories or database files. In addition, the unique secret key can also be retrieved from memory during specific periods.

Fig. 2. Affected authenticator applications

Just Accepted

5 Adversarial model and evaluation criteria

5.1 Adversarial model

The quote by Sun Tze [79], "If you know the enemy and know yourself, you need not fear the result of a hundred battles.", emphasizes the significance of understanding capabilities of one's adversaries to achieve success. This principle is equally relevant in the design of MFA protocols, where threat modeling plays a crucial role in identifying adversarial capabilities and assessing the threats and risks associated with the protocol. Therefore, it is essential to assume a realistic and concrete adversary model when designing MFA protocols. In fact, one of the limitations of most MFA protocols is failing to assume strong and realistic adversaries. Therefore, it is crucial to consider a realistic adversary model when designing MFA protocols. In our model, we consider the following capabilities of the adversary in the MFA context.

- The adversary has full control of messages transmitted over the public channel. For example, it can intercept, eavesdrop, and redirect the messages begin exchanged between the parties over a public channel before they agreed on a session key and established a secure communication channel.
- The adversary can acquire design details of MFA protocols.
- The adversary can acquire the first authentication factor, e.g., password.
- A strong adversary can obtain all the data from the device if he gets access to the device.
- In case of PFS attack, we assume that the adversary can obtain the long-term secrets (e.g., pre-shared keys) of both parties.

5.2 Evaluation criteria

As highlighted in the introduction, establishing a well-defined set of security evaluation criteria is crucial for critically evaluating the security of MFA protocols. A wide range of evaluation criteria are commonly used in the literature, including password exposure, password/PIN strength, password-friendliness, and resilience to known attacks (e.g., impersonation, social engineering, phishing, malware, physical, insider, theft, guessing, privacy breaches, and service leaks) [43, 83]. These criteria are typically employed to evaluate application-level MFA security issues. In this work, we established eight evaluation criteria (outlined in Table 2) that are specifically designed to evaluate and identify design-level security flaws in MFA protocols. As noted in the introduction, these criteria are derived from both existing MFA security requirements and newly introduced considerations. A brief discussion and summary of these evaluation criteria is provided in Table 2.

6 Security analysis of MFA protocols

As mentioned in the preceding sections, we conducted a critical security analysis of several MFA protocols to uncover design-level security flaws. Figure 3 provides a high-level illustration of the MFA processes and potential vulnerability points. For this illustration, we used a multi-factor authenticated key exchange approach in which the client and server authenticate each other and establish a session key to secure their communication channel. In the figure, the designate vulnerability points indicate where the MFA security flaws could occur based on our evaluation criteria (EC1 through EC8). In particular, (1) EC1 indicates where mutual authentication between the client and server must be performed; (2) EC2 indicates where the distinctness of the client's authentication factors (CAF1, CFA2, ..., CFAn) or the server's authentication factors (SAF1, SFA2, ..., SFAn) needs to be verified; (3) EC3 indicates where the independence of the client's or server's authentication factors should be checked; (4) EC4 indicates where communication-level leakage resilience is assessed; (5) EC5 indicates where perfect forward secrecy (PFS) is evaluated; (6) EC6 indicates where user anonymity is verified (i.e., whether an anonymized client ID is used); (7) EC7 indicates where resilience against communication-level known attacks is assessed; and (8) EC8 indicates where the adversarial assumption (covering potential threats to the client, server, and communication channel) is evaluated.

By performing a systematic security analysis, we identified numerous critical security flaws in most of the MFA protocols reviewed. In this section, we provide a detailed analysis and discussion of the security flaws identified in the ten selected MFA protocols. As outlined in Section 4.1, the selection criteria of these protocols were primarily based on the accessibility of its design details and the relevance of the identified security flaws. In addition, considering that the runtime performance of MFA protocols is critically important, especially for resource-constrained devices and systems with strict real-time constraints, we also provide a comparative performance analysis of these protocols in this section.

6.1 Vulnerable MFA Protocol 1 [42]

6.1.1 Protocol description. As highlighted in Section 4.6.2, Jin et al. [42] proposed a historical data-based multi-factor authenticated and confidential channel establishment (HMACCE) protocol for the M2M communication within the IIoT. This protocol involves a client and a server as the communicating entities. The client possesses a long-term symmetric key mk and a tag generation secret key K as first and second authentication factors while the server possesses a long-term symmetric key mk, historical data d_i and data tags t_i as first, second and third authentication factors, respectively. The protocol encompasses three phases, including initialization, tag generation, and online authentication and key exchange. During the tag generation phase, authentication tags are generated using the historical data and data tags, enabling subsequent verifications. This work claimed to address the key leakage issues of a prior historical data-based two-factor authentication protocol [24]. This protocol

Just Accepted

Table 2. Evaluation criteria

S/No.	Evaluation Criteria	Description
EC1	Mutual authentication	Each MFA protocol must ensure that both parties (e.g., client ad server) have verified each other's identities before they advance to the next authentication process and establish the session key.
EC2	Distinctiveness of authentication factors	Every MFA protocol must employ distinct authentication factors selected from different categories, such as knowledge factors, possession factors, inherent factors, or historical data. The rationale behind this requirement is that if an adversary has the capability to compromise an authentication factor in a particular category, he could potentially use the same approach to compromise other factors in the same category. Therefore, MFA protocols must ensure that authentication factors are chosen from distinct categories to enhance security.
EC3	Independence of authentication factors	Each MFA protocol must employ authentication factors that are independent of one another. For instance, the generation of one factor must not rely on another (e.g., using one factor as input for generating another), nor should the security of one factor depend on another (e.g., encrypting one factor with another). If any factor depends on another, compromising one could compromise the other, effectively reducing the MFA protocol to SFA protocol.
EC4	Leakage resilience	Each MFA protocol must ensure that any leakage of intermediary data (e.g., data used in generating authentication factors or session keys) cannot compromise the corresponding factors or keys. Furthermore, authentication factors and session keys must be computationally infeasible for an adversary to predict or guess.
EC5	Perfect forward secrecy (PFS)	Each MFA protocol must ensure that the leakage of long-term keys (client or server) cannot compromise the security of previous sessions.
EC6	User anonymity	During the authentication process, each MFA protocol must preserve the real identity of the users involved.
EC7	Resilience against known attacks	Each MFA protocol must protect the authentication process against known attacks, such as MITM, replay, password-guessing, impersonation, insider, and DoS attacks.
EC8	Adversarial assumption	When designing an MFA protocol, designers must assume strong and realistic adversaries who possess adequate skills and resources to perform sophisticated attacks.

Just Accepted

comprises two versions, namely π_{woFS} and π_{FS}, that are designed without and with forward secrecy, respectively. The latter is also claimed to address the issue of adaptive bounded leakage.

6.1.2 Flaws. Our in-depth security analysis uncovers multiple security flaws of this protocol, as discussed below.

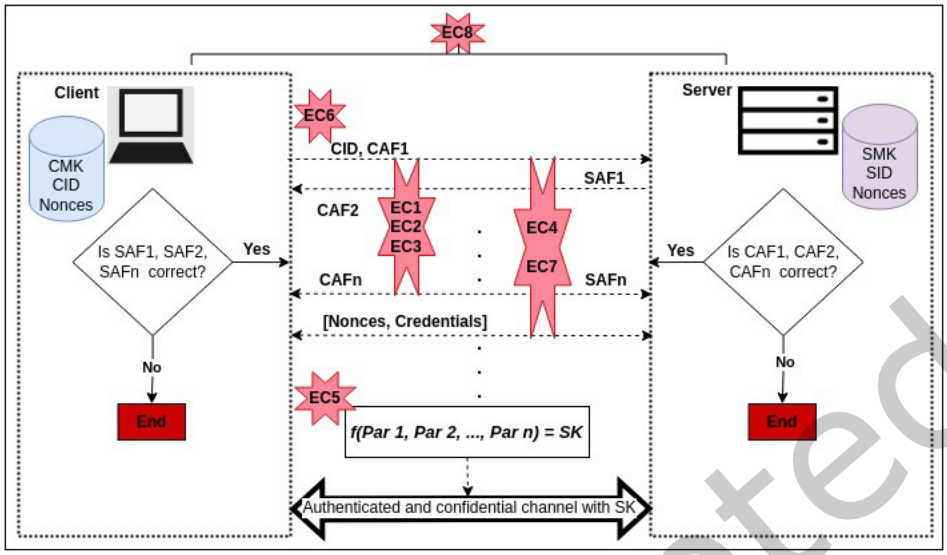

Fig. 3. Illustrating the MFA processes and potential vulnerability points

Description of notations: CAF: Client Authentication Factor, CID: Client ID, CMK: Client Master Key, Par: Parameter, SAF: Server Authentication Factor, SID: Server ID, SMK: Server Master Key

Just Accepted

(1) According to the authentication steps outlined in this protocol, only the client authenticates the server by verifying the authentication message $M = h(mk||Y||sid||Auth')$ sent by the server. However, there is no mechanism for the server to authenticate the client, as the client does not send any authentication message. Consequently, the protocol fails to meet the mutual authentication criterion (*EC1*).
(2) Both of the client's authentication factors – the long-term symmetric key mk and the tag generation secret key K – belong to the same authentication factor category, namely possession factors. This indicates that multiple authentication factors are drawn from the same category. Therefore, this protocol fails the authentication factors distinctiveness criterion (*EC2*).
(3) During the tag generation phase, the data tags t_i (i.e., the server's third authentication factor) are generated from the historical data t_i (i.e., the server's second authentication factor) using the tag generation key K (i.e., the client's second authentication factor). The equation to do that is: $t_i = K.h(d_i||i) + k_i(modp)$, where $k_i = h(K||i)$. This implies that the computation of t_i depends on both the client's and server's second authentication factors. That means, any compromise of the client's or server's second authentication factor could potentially compromise the server's third authentication factor. Thus, this protocol fails the independence of authentication factors (*EC3*) criterion.
(4) This protocol is also susceptible to data- and tag-stealing attacks in which adversaries could retrieve all the historical data and tags. Since data and tags are used as authentication factors, such leakage can also compromise the authentication factors and the session keys. Therefore, it fails the leakage resilience criterion *EC4*.
(5) The entropy of its sensor data (which is used as authentication factor) is also between 4.52 and 7.80, which is low and could easily be predicted. Hence, it fails the evaluation criterion *EC4* again.
(6) This protocol does not employ any client anonymity mechanism, thus failing evaluation criterion *EC6*.

(7) The work assume a weak adversary (called a bounded-retrieval model) who can access only a fraction of the historical data after he compromises the server. This is an unrealistic assumption and fails the evaluation criterion *EC8*. On the other hand, the second version (i.e., π_{FS}) of this protocol satisfies PFS while the first version (i.e., π_{woFS}) does not.

6.2 Vulnerable MFA Protocol 2 [36]

6.2.1 Protocol description. As highlighted in Section 4.6.1, Mirsaraei et al. [36] proposed an ECC-based MFA protocol on a blockchain platform for generic IoT devices. It involves a user device (client) and server as the communicating entities. It employs a password, biometric, and smart card as authentication factors. An informal and formal (e.g., using the AVISPA tool) analysis was conducted in this work and claimed that the protocol is capable of satisfying a set of established security requirements and resisting attacks including key leakage, MITM attacks, DoS attacks, etc.

6.2.2 Flaws. Our in-depth analysis of this protocol reveals several security flaws, as detailed below.

(1) In this protocol, the session key is computed using the equation $SK = M_2 \oplus V_1$. Given that a strong adversary could potentially acquire the information discussed in the threat model (refer Section 5.1), the adversary can also compute this session key as follows. The adversary can easily obtain the values of M_2 and V_1 to compute SK. This is because, M_2, which is transmitted through the insecure channel from the server to the client, can be easily retrieved by eavesdropping. Similarly, GID_i can be retrieved by the adversary through eavesdropping since it is also transmitted through the insecure channel from the client to the server. ID_i can also be eavesdropped as it is transmitted through the insecure channel during the user registration or password/biometric updating phases. Due to its low entropy, the adversary could also acquire ID_i through other forms of attacks such as guessing, leaking, phishing, keylogging, malware, etc. Then, V_1 can be computed by inverting the equation $GID_i = ID_i \oplus V_1$, i.e., $V_1 = GID_i \oplus ID_i$. Finally, SK can be computed as $SK = M_2 \oplus V_1$. Therefore, this protocol does not achieve the leakage resilience (*EC4*), PFS (*EC5*) and resilience against known attacks (*EC7*) evaluation criteria.
(2) This protocol does not also employ any mechanism to anonymize the user's identity ID_i. In fact, it is transmitted in plain during the registration and password updating phases, hence failing *EC6*.
(3) In this protocol's security analysis, it was assumed in "Assumption 5" that *"the malicious attacker can obtain only one parameter in an equation at a time"*. Considering that a strong adversary can employ various sophisticated techniques and strategies to acquire multiple parameters simultaneously, the adversarial assumption of this work is weak and unrealistic, hence failing the evaluation criteria *EC8*.

6.3 Vulnerable MFA Protocol 3 [91]

6.3.1 Protocol description. As highlighted in Section 4.6.1, Zahednejad et al. [91] proposed a two-factor authentication protocol for generic IoT devices in an M2M context. This protocol involves a client and a server as the communicating entities. It employs a long-term pre-shared key (mk) and historical data items as first and second authentication factors, respectively, for both entities. To simulate real-life scenarios, this work assumed a strong adversary capable of compromising the server and retrieving all the information within. This work also employed ROR model to to formally prove how the protocol achieves perfect forward secrecy and key compromise resilience.

6.3.2 Flaws. Our extended security analysis uncovers several security flaws of this protocol, as discussed below.

(1) First of all, the construction of the authentication process in this protocol is entirely reliant on the first authentication factor (i.e., mk). Because, all secret seeds and nonces are protected by XORing with mk before being transmitted over the public channel. Consequently, if an adversary manages to obtain mk, it

Just Accepted

can easily forge the entire authentication process as everything hinges on the first factor. As a result, this protocol fails to meet the independence of authentication factors ($EC3$) criterion.

(2) In addition, according to the threat model, the adversary can obtain $N-1$ authentication factors and eavesdrop any information transmitted over the public communication channel. Under these assumptions, it is possible for the adversary to acquire the values of $R1$, $R2$, Y and TID_c used in this protocol, as are transmitted in plain via the public channel. Additionally, the adversary could acquire one of the authentication factors, such as the first factor, mk. Since spk_s is the server's public key, it is publicly available and can also be easily acquired by the adversary. Using this information, the adversary can compute $r1$, $r2$, and X, which are secret seeds used to generate the session key SK_s, through the following equations: (a) $r1 = mk \oplus R1$; (b) $r2 = mk \oplus R2$; (c) $X = Y - H(r1||r2)$; As a result, this protocol fails to satisfy the leakage resilience ($EC4$) criterion.

(3) Furthermore, using the above acquired and computed values, the adversary can compute the value of the session key SK_s as follows and decipher any information protected by it: $SK_s = H(mk|r1|r2|X|TID_c|spk_s)$. Consequently, this protocol also fails the perfect forward secrecy ($EC5$) and resilience against known attacks ($EC7$) criteria.

6.4 Vulnerable MFA Protocol 4 [47]

6.4.1 Protocol description. As highlighted in Section 4.6.4, Kumar et al. [47] proposed a three-factor authentication protocol designed for wireless sensor networks. The protocol involves three communicating entities: the user, the base station, and the sensor node. It employs a password, smart card, and biometric as authentication factors. To evaluate its security, this work employed the ROR model and the AVISPA tool. It claimed that the protocol satisfies several security requirements, including mutual authentication, secure session key agreement, user anonymity, and resilience against password guessing, replay, and impersonation attacks.

6.4.2 Flaws. Our security analysis uncovers the following security flaws in this protocol.

(1) First of all, a strong adversary was not considered in this work's threat model, hence failing the adversarial assumption ($EC8$) criterion.

(2) The information that is directly or indirectly used in the session key generation, such as ID^i_{sn}, N_{ur}, $h(RN_{sc})$, TS_1, and TS_5, are transmitted over the open communication channel. Hence, it can be intercepted by a strong adversary. Using the intercepted information and considering the MFA threat assumption that $N-1$ authentication factors (e.g., the password or smart card), the adversary can compute the session key as follows:

$$K_{ss} = h(ID_{ur}||ID^i_{sn}||U^i_{rg}||h(ID_{ur}||N_{ur})||h(RN_{sc})||TS_1||TS_5)$$

Here, it is possible to infer that the value TS_5 corresponds to a particular session key by examining the value of I_{10} (used in this protocol), which is defined as $I_{10} = (h(K_{sh} \oplus U^i_{rg})||ID_{ur})$. According to Kerckhoffs's principle [64], and given that hash values have a fixed length, the adversary can deduce the length of $h(K_{sh} \oplus U^i_{rg})$. Using this information, the adversary can extract the value of ID_{ur} by stripping away the bits corresponding to the hash value. This enables the adversary to determine whether TS_5 pertains to the targeted user attempting to establish a secure communication channel, resulting in breaches of both security and anonymity. Overall, in addition to $EC8$ mentioned above, this protocol fails multiple evaluation criteria, such as leakage resilience ($EC4$), PFS ($EC5$), user anonymity ($EC6$), and resilience against known attacks ($EC7$).

Just Accepted

6.5 Vulnerable MFA Protocol 5 [14]

6.5.1 Protocol description. As highlighted in Section 4.6.3, Azrour et al. [14] designed a two-factor authentication protocol for HIoT systems, aimed to address the vulnerabilities of a prior work [72]. The protocol involves three communicating entities: a user (medical professional), a sensor node, and a cloud server. It employs password and smart card as authentication factors to secure remote communications between these entities. To validate the security of this protocol, both informal and formal security analyses were conducted in this work, using the ROM model and the Scyther tool for the latter.

6.5.2 Flaws. Upon performing a detailed security analysis, we discovered the following security flaws in this protocol.

(1) First of all, this work did not clearly define a threat model or specify the capabilities of the assumed adversaries, thereby failing the adversarial assumption (*EC8*) criterion.
(2) Additionally, in its formal and informal analysis, this work claimed to achieve perfect forward secrecy by assuming that the values of x_s and MID remain secret. However, our analysis of this protocol demonstrates the opposite, as explained below.
  (a) MID is transmitted in plain over the public channel, meaning it is not kept secret.
  (b) A strong adversary could potentially obtain the value of x_s from the cloud server through alternative means. With x_s in hand, the adversary could compute w_i, which is used to derive the session key S_{key} using the equation $w_i = h(MID||x_s)$.
  (c) Id_{SN} is also transmitted plainly over the public channel, making it susceptible to eavesdropping.
  (d) Using the values of w_i, MID and Id_{SN}, the adversary could compute the session key S_{key} using the equation $S_{key} = h(w_i||MID||Id_{SN})$.
  (e) Therefore, this protocol fails multiple evaluation criteria, including leakage resilience (*EC*4), PFS (*EC*5), user anonymity (*EC*6), and resilience against known attacks (*EC*7).

6.6 Vulnerable MFA Protocol 6 [9]

6.6.1 Protocol description. As highlighted in Section 4.5, Ali et al. [9] proposed a three-factor symmetric key-based MAKE protocol for Telecare Medicine Information Systems (TMIS), designed to address the vulnerabilities of a prior work [19]. The protocol involves three communicating entities: a user, a registration center, and a server. It employs a password, smart card, and biometrics as authentication factors. Additionally, a revocation/re-registration phase was included to allow user revocation in the event of a smart card loss. Based on its informal and formal analyses, this work claimed that the protocol is resilient against key leakage, impersonation, and known attacks.

6.6.2 Flaws. Our analysis of this protocol uncovers several security flaws, as highlighted below.

(1) The proposed MFA protocol computes its session key SK_{ij} as follows:

$$SK_{ij} = h(Y_{RC}||SID_j||T_3) == SK_{ij}^{'} = h(Y_i||SID_j||T_3)$$

Through our analysis, the values of SID_j and T_3 can be intercepted from the open communication channel. It is also possible to compute the value of Y_i using the equation: $Y_i = h(SID_j||HID_i^{'}||R_{rand2}||T_1)$, where:
- $HID_i^{'} = h(PID_i)$ (PID_i can be acquired by compromising the first authentication factor);
- $R_{rand2} = R_{rand2}^{'} \oplus ID_i$ ($R_{rand2}^{'}$ can be acquired by intercepting the message from the open communication channel);
- $T_1 = T_1^{'} \oplus HID_i^{'}$ ($T_1^{'}$ can be acquired by intercepting the message from the open communication channel);

Just Accepted

Using the above information acquired, the adversary can compute the value of the session key SK_{ij} and decipher the information secured by it. As a result, this protocol fails multiple evaluation criteria, including leakage resilience ($EC4$), PFS ($EC5$), and resilience against known attacks ($EC7$).

(2) Furthermore, this work assumed that the adversary cannot steal the private key of the registration center, which is a weak adversarial assumption since such keys can be compromised through side-channel attacks or other techniques. This also leads to the protocol failing the adversarial assumption ($EC8$) criterion.

6.7 Vulnerable MFA Protocol 7 [80]

6.7.1 Protocol description. As highlighted in Section 4.2, Ertan et al. [80] proposed a two-factor authentication protocol for a generic client-server architecture. The protocol was designed to enhance the security posture of TOTP systems. It involves two communicating entities: a client and a server. The protocol uses TOTP as the first authentication factor and PUF as the second authentication factor, with the PUF serving as secure storage for the client's secret. This work assumed that the communication channel between the client and the server is secured via TLS.

6.7.2 Flaws. Through our analysis, we have identified several security flaws in this protocol, as outlined below.

(1) It is evident from the authentication process that this protocol enables only the server to authenticate the client, but not vice versa. Consequently, the protocol fails to meet the mutual authentication ($EC1$) criterion.

(2) Additionally, it overlooks other key security requirements in MFA, such as leakage resilience ($EC4$), PFS ($EC5$), user anonymity ($EC6$), resilience against known attacks ($EC7$), and strong adversarial assumption ($EC8$).

6.8 Vulnerable MFA Protocol 8 [68]

6.8.1 Protocol description. As highlighted in Section 4.6.1, Sadhukhan et al. [68] introduced an ECC-based lightweight three-factor authentication protocol for remote users in a generic IoT network. It involves three communicating entities: a user (smart device), an IoT node, and a gateway. It employs three authentication factors: user identity, password, and biometric data. Through its informal security analysis, this work claimed that the proposed MFA protocol achieves several security requirements, including resilience against impersonation and DoS attacks, PFS, and user anonymity, among others.

6.8.2 Flaws. Our evaluation reveals that this protocol suffers from multiple security flaws, as summarized below.

(1) This work claimed to achieve mutual authentication by hashing the three authentication factors, i.e., $H_U = h(ID_U||PW_U||B_U)$. However, this hash value, along with R_U, is encrypted using K_X (i.e., $E_{K_X}(H_U||R_U)$) and transmitted to other entities over the public channel during the authentication and key exchange processes. That means, the security of the authentication process relies solely on the pre-shared key K_X, undermining the effectiveness of other authentication factors. Therefore, this protocol fails to achieve mutual authentication (*EC1*) and independence of authentication factors (*EC3*).

(2) Additionally, this protocol fails to adequately protect the authentication factors, as the user ID and biometric data are transmitted in plain text over the public communication channel during the authentication process, making them vulnerable to interception by an adversary. Consequently, it fails the leakage resilience ($EC4$) criterion.

(3) Furthermore, this work claimed to achieve PFS just by assuming that the secret random number R_U used in the session key generation cannot be compromised by an attacker even if the pre-shared symmetric key K_X is compromised. However, this assumption is flawed. If an attacker obtains K_X (which is the underlying assumption in PFS), he can intercept and decrypt the packets transmitted over the public channel to retrieve

Just Accepted

R_U, since R_U is solely protected by K_X. This is also the mechanism used by the gateway to obtain R_U in this protocol. Consequently, the protocol fails to meet the PFS (*EC5*) criterion.

(4) This work also claimed to achieve user anonymity by assuming that the user's identity, ID_U, is never transmitted in plain. However, during the authentication phase, the user sends ID_U in plain to the IoT node over the public channel. This allows an adversary to easily intercept it through eavesdropping. As a result, the protocol fails to meet the user anonymity (*EC6*) criterion.

(5) This protocol does not also achieve resilience against known attacks nor provide realistic adversarial model, hence failing *EC7* ad *EC8*.

6.9 Vulnerable MFA Protocol 9 [32]

6.9.1 Protocol description. As highlighted in Section 4.5, Dhillon et al. [32] proposed a three-factor MFA and key exchange protocol for a healthcare system. In particular, it is designed to establish a secure communication channel between a medical professional (MP) and a remote patient monitoring in Cloud-IoT environments. The protocol involves a medical professional and cloud server as the communicating entities. It employs a password, biometrics, and smart card as authentication factors. This work claimed to have achieved several security goals, such as mutual authentication, user anonymity, forward secrecy and many other known attacks.

6.9.2 Flaws. Our analysis on this protocol reveals the following security flaws.

(1) Although the protocol is designed to use three authentication factors, the credentials derived from the user's password (first authentication factor) and biometric feature (second authentication factor) are stored on the smart card (third authentication factor). This dependency makes the first two factors reliant on the safety and security of the third factor, thereby failing to meet the independence of authentication factors (*EC3*) criterion.

(2) In addition, this work claimed to achieve PFS by relying on the MP's identity (ID_{MP}), its private key X, and other parameters c and u. However, this claim is flawed for several reasons. First, u is transmitted over a public channel, making it vulnerable to interception. Second, the premise of PFS assumes that an adversary can compromise the long-term credentials of the client and server (i.e., X), meaning the protocol cannot rely on X to achieve PFS. Third, c is derived using the private key of the cloud server, which faces the same vulnerability as X. Finally, ID_{MP} is stored on both the client and cloud server, making it susceptible to compromise through the same way or in various other methods. As a result, this protocol fails to meet the PFS (*EC5*) criterion.

(3) Furthermore, this protocol does not provide resilience against session key or long-term key leakage attacks or other known attacks. This work also did not put a strong adversarial assumption that could compromise identities and credentials of the user and cloud server. Therefore, the protocol also fails several security criteria, including leakage resilience (*EC4*), resilience against known attacks (*EC7*), and realistic adversarial assumption (*EC8*).

6.10 Vulnerable MFA Protocol 10 [56]

6.10.1 Protocol description. As highlighted in Section 4.6.1, Melki et al. [56] proposed a lightweight ECC-based two-factor authentication protocol to provide secure communication channels between an IoT device and a gateway. The protocol involves an IoT device and a gateway as the communicating parties. It employs a secret session identifier ID_s (that is derived from a PUF output value) and a secret channel-based parameter σ_i as authentication factors. This work claimed to have achieved several security properties, such as PFS, session secrecy, user privacy, and resilience against reply, side-channel and man-in-the-middle attacks.

6.10.2 Flaws. Our investigation uncovers several security flaws of this protocol, as elaborated below.

Just Accepted

(1) First of all, the assumed authentication factors, i.e., ID_s and σ_i, are inappropriate and prone to several security vulnerabilities. Moreover, both factors belong to the same authentication factor category, i.e., possession factors. Therefore, it fails to meet the distinctiveness of authentication factors (*EC2*) criterion.
(2) In addition, the proposed protocol is vulnerable to both client and server impersonation attacks. An adversary could potentially obtain the list of ID_s from the gateway. As it is evidently shown in the protocol, the adversary can also plant itself between the IoT device and the gateway and establish separate communication channels with either of them. Hence, this protocol does not achieve leakage ($EC4$) resilience and resilience against known attacks ($EC7$).
(3) Furthermore, this work claimed to have achieved PFS just by considering the one-way property of a hash function and the secrecy of the session identifier ID_s. This is also an unrealistic assumption. Because, the ID_s is not properly secure (as discussed above) and the other parameters (e.g., timestamp) are transmitted over the public channel. More importantly, this work's assumption of PFS is different from the actual definition. In reality, PFS is a critical security requirement in key exchange, which requires that past session keys remain secure even if the long-term credentials of both the client and the server are compromised. Therefore, this protocol does not achieve PFS ($EC5$) in many ways.
(4) Additionally, this work assumes that "the adversary's probability of obtaining ID_s is exceptionally low" is unrealistic, and it undermines the principal threat assumption of MFA, where an adversary is presumed to compromise $N - 1$ authentication factors. In fact, there are several ways to obtain ID_s, e.g., via side-channel techniques, as it is stored in the client and server devices. Therefore, the adversarial assumption is unrealistic, hence failing *EC8*.

6.11 Summary of the security analysis

Our security analysis reveals that not all MFA protocols are free from weaknesses. Table 3 summarizes the results of our evaluation of ten MFA protocols based on our evaluation criteria. A key takeaway from this analysis is that the inclusion of more authentication factors does not necessarily guarantee stronger security. As demonstrated in our analysis, many of the MFA protocols evaluated fail to address the critical security requirements outlined in our evaluation criteria.

7 Mitigation strategies, challenges, and future research directions

In Section 6, we demonstrated that most MFA protocols exhibit weaknesses and flaws that adversaries could exploit to gain unauthorized access to systems and applications. In this section, we discuss our recommended mitigation strategies that can be potentially used to address the identified flaws. Some of these strategies are based on our own recommendations, while others represent best practices compiled from existing works. Additionally, we discuss the potential challenges involved in implementing these strategies and outline areas of future research. Table 4 provides a summary of the recommended mitigation strategies, their associated challenges, and future research directions.

7.1 Mutual authentication

As noted in the preceding sections, most MFA protocols were not designed to incorporate mutual authentication [13]. However, with the rise in scams [29], it has become increasingly evident that people need the assurance that the entities they interact with are trustworthy and legitimate. It is no longer sufficient for organizations to verify the authenticity of individuals; they must also prove their own identity to those individuals during interactions.

7.1.1 Mitigation strategies. Mutual authentication can be achieved in many ways. One of the most commonly adopted approaches is using digital certificates in which users authenticate each other through their respective CA-issued public keys. However, due to its high performance overhead, it may not be an ideal solution for

Just Accepted

Table 3. Security evaluation results of the 10 MFA protocols

Protocol	Domain	Authentication Factors	Evaluation Criteria							
			EC1	EC2	EC3	EC4	EC5	EC6	EC7	EC8
Protocol 1 [42] (π_{woFS})	IIoT	LSK + TGK^c + HD^s + HDT^s	×	×	×	×	×	×	✓	WA
Protocol 1 [42] (π_{FS})	IIoT	LSK + TGK^c + HD^s + HDT^s	×	×	×	×	✓	×	✓	WA
Protocol 2 [36]	Generic IoT	PW + SC + BD	✓	✓	✓	×	×	×	×	WA
Protocol 3 [91]	Generic IoT	LSK + HD	✓	✓	×	×	×	✓	×	SA
Protocol 4 [47]	WSN	PW + SC + BD	✓	✓	✓	×	×	×	×	WA
Protocol 5 [14]	HIoT	PW + SC	✓	✓	✓	×	×	✓	×	WA
Protocol 6 [9]	Healthcare	PW + SC + BD	✓	✓	✓	×	×	✓	×	WA
Protocol 7 [80]	Client-Server	TOTP + PUF	×	✓	✓	×	×	×	×	WA
Protocol 8 [68]	Generic IoT	UID + PW + BD	×	✓	×	×	×	×	×	WA
Protocol 9 [32]	Healthcare	PW + SC + BD	✓	✓	×	×	×	✓	×	WA
Protocol 10 [56]	Generic IoT	SSID + SCP	✓	×	✓	×	×	✓	×	WA

Description of notations: EC1: Mutual Authentication, EC2: Distinctiveness of Authentication Factors, EC3: Independence of Authentication Factors, EC4: Leakage Resilience, EC5: Perfect Forward Secrecy, EC6: User Anonymity, EC7: Resilience Against Known Attacks, EC8: Adversarial Assumption, LSK: Long-term Shared Key, TGK: Tag Generation Key, HD: Historical Data, HDT: Historical Data Tags, X^c: factor X is only for Client, X^s: factor X is only for Server, PW: Password, SC: Smart Card, BD: Biometric Data, TOTP: Time-based Ontime Password, PUF: Physical Unclonable Function, UID: User Identity, SSID: Secret Session Identifier, SCP: Secret Channel-based Parameter, WA: Weak Adversary, SA: Strong Adversary

Just Accepted

most resource constrained systems, such as IoT. An ideal approach to address this problem is a cryptographic construction where both parties can present provable credentials or factors to prove their identity. One such approach is properly utilizing shared cryptographic keys in a challenge-response manner. For example, the server can compute the response to a random nonce with the shared cryptographic key and compare it with the response computed by the client. If the response matches, the client is authenticated. Similarly, the client will compute the response to another random nonce with the shared cryptographic key and compare it with the response computed by the server. The server is authenticated if the responses match. Kim et al. [46] used such approach to ensure mutual authentication between entities. It was achieved by verifying messages that were computed using shared secret parameters distributed during the registration phase. Using the shared secret parameter S_i^1, the user and the gateway will mutually authenticate each other by verifying the correctness of messages GM_5 and U_iM_8, respectively.

Oh et al. [59] also adopted a similar approach to achieve mutual authentication. The shared secret keys K_{MUG} and K_{GSD} stored in the Home Gateway (HGW) are used to verify the identity of the user and smart device, respectively. The user and smart device will also utilize the same keys to verify the identity of the HGW to achieve mutual authentication.

Another interesting approach to achieve mutual authentication is by proving a possession of a piece of data that allows both parties to authenticate each other. For example, Zahednejad et al. [91] utilized historical data that were shared between the parties, which allows them to prove each other's identity in a challenge-response manner.

For higher assurance, a more rigorous approach can be adopted using formal methods, such as BAN logic [22, 85], that several researchers used to evaluate the security of their MFA protocols [27, 45, 59, 61, 84], to further prove mutual authentication.

7.1.2 Potential challenges. The above mitigation strategies come with certain potential challenges. For instance, utilizing shared cryptographic keys involves the cost of updating or rekeying the shared secrets and poses a risk to PFS if a key is compromised. Similarly, employing provable credentials can raise privacy concerns when credentials are reused.

7.1.3 Future research direction. Given its importance in MFA, new solutions are anticipated to enhance the achievement of mutual authentication. In this context, developing robust and context-aware mutual authentication mechanisms, potentially incorporating AI-driven analytics, presents a promising direction for future research.

7.2 Distinctiveness of authentication factors

For an MFA protocol to be fully effective, one of the key design requirement is distinctiveness of its authentication factors. However, as demonstrated in our analysis, most MFA protocols do not achieve this criteria.

7.2.1 Mitigation strategies. Authentication factors within the same category often share a similar security level. As a result, if an adversary successfully compromises one factor, they may be able to exploit the same technique to breach others within the same category. For instance, Jin et al. [60] (discussed in Section 6.1) utilized both a pre-shared symmetric key and a tag generation symmetric key as the first and second authentication factors for the client, respectively. Since both factors fall under the possession category, an adversary could potentially use a similar approach to compromise them. To address this issue, the main mitigation strategy is ensuring that MFA protocols incorporate distinct authentication factors that are drawn from different categories, such as knowledge, possession, inherent, and location factors. For example, Mirsaraei et al. [36] and Kumar et al. [47] followed a similar approach to achieve this requirement.

7.2.2 Potential challenges. Implementing the above mitigation strategy is not expected to pose significant challenges. However, the primary potential challenge could be the cost associated with implementing and maintaining multiple types of authentication factors. Additionally, usability could become an issue for users if the selected factors are not carefully designed and chosen to ensure ease of use.

7.2.3 Future research directions. A potential future research direction to ensure the uniqueness of authentication factors could involve systematically designing the selection of distinct authentication factors in a context-aware manner while also prioritizing usability. Additionally, exploring and developing new types of authentication factors beyond the conventional categories could present another valuable area for future research.

7.3 Independence of authentication factors

The independence of authentication factors is a vital security requirement in MFA, ensuring that the compromise of one factor does not jeopardize other factors. However, this requirement is not fulfilled by most existing MFA protocols.

7.3.1 Mitigation strategies. The independence of authentication factors can be achieved through several approaches. However, we emphasize two key methods to meet this MFA requirement:

(1) The generation of an authentication factor must be independent of other factors, meaning it should not be derived from any other authentication factor.
(2) One authentication factor should not be used to protect the confidentiality of another authentication factor.

Lee et al. [50] demonstrated the independence of authentication factors in their MFA protocol, ensuring that a compromise of any single authentication factor does not lead to the compromise of the others. Similarly, Vinoth et al. [82] showed that in their MFA protocol, even if $N-1$ authentication factors are compromised, the remaining authentication factor remains secure, preserving the integrity of the overall authentication process.

Just Accepted

7.3.2 Potential challenges. Implementing the above mitigation strategies to ensure authentication factor independence may present several challenges, including operational and usability issues, scalability problems in large-scale systems, and the increased cost of securing each factor individually.

7.3.3 Future research directions. To achieve independence of authentication factors, designing an MFA protocol that utilizes cross-domain and decentralized authentication factors would be a promising research direction in the future.

7.4 Leakage resilience

Ensuring resilience against data or key leakage is a complex task and a crucial security requirement in the design of MFA protocols. It requires thorough consideration to address every potential data or key leakage scenario. However, as demonstrated in our analysis, most MFA protocols fail to meet this critical requirement.

7.4.1 Mitigation strategies. There is no one-size-fits-all design to achieve key or data leakage resilience and every MFA protocol would require a tailored approach based on the requirements of the systems and the potential threats the system is exposed to. However, there are some guiding principles that can be adhered to achieve this objective.

Given that the initial authentication process is typically conducted through open communication channels, researchers should ensure that not all parameters utilized in the session key generation are transmitted in clear. In addition, the parameters used in the generation of session keys should not be easily computed using information obtained through the open communication channels and compromise of the authentication factors. One example is the MFA protocol designed by Kwon et al. [49]. In this protocol, the equation used to compute the session key is $SK = h(h(N_2||HID_i)||N_3||N_1)$. None of the parameters used in the session key computation were transmitted in plain over the open communication channel. To retrieve the random nonces $N1$, $N2$, and $N3$, an adversary would need to compromise all three entities involved – namely, the user, gateway, and sensor node – or compromise other secret keys, or both authentication factors, to access the parameters used to protect the random nonces.

In addition, achieving high entropy for cryptographic keys and random nonces is essential for ensuring leakage resilience. High entropy minimizes the chances of adversaries obtaining sensitive information through guessing or brute-force attacks, which could directly or indirectly compromise session keys [16].

Furthermore, adhering to established key management guidelines from reputable organizations, such as NIST [16–18], can further enhance the overall security of the authentication process. As technology advances, cryptographic key lengths once considered secure may become vulnerable. Therefore, it is crucial to stay up-to-date with the latest recommended cryptographic standards [58] and regularly review the security of MFA protocols to maintain their effectiveness.

7.4.2 Potential challenges. The main potential challenges associated with the three mitigation strategies discussed above would include the cost of securing parameters (particularly during the initialization phase), the risk of entropy source compromise (e.g., through side-channel attacks), and the cost of implementing effective key management practices.

7.4.3 Future research directions. In the future, robust leakage resilience strategies will be pivotal in enhancing the security of MFA protocols and related systems. In this regard, the development of self-evolving and high-entropy keys and authentication factors represents a critical area for future research.

Just Accepted

7.5 Perfect forward secrecy (PFS)

PFS is a crucial security requirement in MFA, ensuring that previous session keys cannot be derived from the long-term keys of the communicating parties. However, as our analysis shows, most MFA protocols fail to satisfy this requirement.

7.5.1 Mitigation strategies. PFS is a challenging security requirement to achieve. Its core principle is to ensure that session keys remain independent of long-term private keys, so that the compromise of a private key does not jeopardize past session keys. For example, Jin et al. [42] uses one authentication procedure as a compiler to transform a general passively secure two-message key exchange protocol to achieve PFS. In general, attaining PFS necessitates a multilayered approach incorporating various strategies, such as strong cryptographic protocols, multi-party computation (MPC), and secure key management, among others.

7.5.2 Potential challenges. Achieving PFS using the above strategies may pose certain challenges, including complexities of managing short-lived (ephemeral) keys, quantum threats, and backward compatibility issues (i.e., unable to support legacy systems).

7.5.3 Future research directions. Designing new cryptographic constructions that systematically decouple session keys from long-term private keys represents a promising research direction for achieving PFS. These strategies could leverage post-quantum cryptographic (PQC) primitives, multi-party computation (MPC), and decentralized computation techniques.

7.6 User anonymity

User anonymity is a crucial requirement in MFA, allowing users to be authenticated without disclosing their actual identities. It has gained significant importance as people become more aware of the need to protect their personal information and identity. In addition, organizations are required to comply with privacy regulations [31, 35, 74]. However, as our analysis indicates, most MFA protocols fail to meet this requirement.

7.6.1 Mitigation strategies. User anonymity can be achieved through various ways. The most widely used approaches the use of pseudonymous identities. This involves issuing users a pseudo-identity that conceals their actual identity. For instance, in the registration phase of the MFA protocol by Kim et al. [46], the gateway generates a pseudo-identity TID_i based on the user's actual identity ID_i, the gateway's secret key K_{GW}, and a randomly generated nonce R^1_{GW}. During authentication, TID_i is used instead of ID_i, and it is refreshed each time with a new pseudo-identity TID_i^{new}, further enhancing anonymity.

Alternatively, cryptographic techniques can be employed to safeguard user anonymity during authentication. These techniques include encryption, hashing, and mathematical operations such as concatenation and XOR. For example, in the MFA protocol proposed by Bouchaala et al. [21], the user's actual identity ID_u is never transmitted in plain. Instead, cryptographic methods are used to generate PID_u, which is then utilized in the authentication process to ensure anonymity.

7.6.2 Potential challenges. The above mitigation strategies come with certain potential challenges. For the pseudonymous approach, the main challenges include transparency issues (e.g., in certain cases where identity disclosure is required) and susceptibility to adversarial attacks. On the other hand, the main challenge of the cryptographic approach is the risk of side-channel attacks targeting cryptographic keys.

7.6.3 Future research directions. As user privacy remains a critical concern across various domains, exploring new user anonymity strategies, even beyond pseudonymous identities, presents a compelling direction for future research. This could involve leveraging blockchain-based and post-quantum cryptography approaches to further enhance anonymity.

Just Accepted

Table 4. Summary of recommended mitigation strategies, potential challenges, and future research directions

Evaluation Criteria	Recommended Mitigation Strategies	Potential Challenges	Future Research Directions
Mutual authentication	(1) Cryptographic computations and verifications using shared secret keys [46, 59]. (2) Both parties presenting appropriately provable credentials or factors to each other to prove their identity [91].	– For (1), rekeying of shared secret keys, risking PFS in case of key compromise. – For (2), privacy issues when reusing credentials.	Design of robust and context-aware mutual authentication mechanisms.
Distinctiveness of authentication factors	Ensure that the authentication factors are drawn from different authentication factor categories [36, 47].	– Implementation and maintenance cost of employing different types of factors.	Selection of usability-aware distinct factors, and discovery of new authentication factors.
Independence of authentication factors	(1) Generation of an authentication factor must be unique and should not be derived from the knowledge of another authentication factor [50, 82]. (2) an authentication factor must not be used to protect the confidentiality of other authentication factors.	– For (1), usability and scalability (for large-scale systems) issues. – For (2), increasing cost of protecting each factor separately.	Design of new MFA systems that avoid inter-factor dependence.
Leakage resilience	(1) Do not transmit all parameters utilized in the session key generation in clear [49]. (2) Achieve high entropy of the cryptographic keys and random nonces [16]. (3) Perform proper key management in line with guidelines by reputable organizations such as NIST [16–18].	– For (1), securing parameters is costly, especially during initialization phase. – For (2), compromise of entropy sources, e.g., via side-channel attacks. – For (3), cost of key management.	Design of cross-domain and decentralized authentication factors.
Perfect forward secrecy (PFS)	Using new cryptography constructions and other strategies, e.g., PQC primitives and MPC, ensure that the compromise of long-term keys do not jeopardize the security of session keys in MFA.	– Complexities of managing ephemeral keys, quantum threats, and backward compatibility issues.	New cryptographic constructions that decouple session keys from long-term keys.
User anonymity	(1) [46]. (2) Utilize cryptographic techniques to protect the anonymity of individuals [21].	– For (1), transparency issues, and adversarial attacks. – For (2), side-channel attacks to cryptographic keys.	Design of new user anonymity schemes, beyond the use of pseudonymous identities.
Resistance to known attacks i.e., impersonation and DoS attacks	(1) Do not transmit sensitive information in clear that directly or indirectly affects the security of MFA protocols [59]. (2) Protect parameters such as random nonces using cryptographic techniques and ensure that compromise to $N-1$ authentication factors would not affect the security of the MFA protocols [59].	– For (1), cost of securing all sensitive data. – For (2), performance cost and side-channel attacks to cryptographic keys.	Design of adaptive, unpredictable, and context-aware MFA approaches.
Adversarial assumption	Adopt a realistic approach and accord the adversary with appropriate capabilities [91].	Requires resource and effort to accurately understand and model capabilities of the adversary in certain contexts.	Design of adaptive, dynamic, and context-aware threat modeling.

Just Accepted

7.7 Resistance to known attacks

Known attacks, such as MITM, replay, phishing, and side-channel attacks, remain significant security challenges in MFA. However, as revealed inour analysis, most MFA protocols lack resilience against these threats.

7.7.1 Mitigation strategies. There are multiple approaches to defending against known attacks, with the choice of security mitigation strategies depending on specific requirements and constraints. For instance, a widely adopted method to counter eavesdropping or interception attacks in MFA is to ensure that sensitive information is never transmitted in plain between users [59]. This reduces the adversary's ability to derive session keys or

authentication factors from exchanged data. Another common approach involves securing critical parameters, such as random nonces, using cryptographic techniques to ensure that even if $N - 1$ authentication factors are compromised, the overall security of the MFA protocol remains intact [59].

7.7.2 Potential challenges. Some potential challenges associated with the above mitigation strategies include the cost of securing all sensitive data transmitted over public channels, the performance overhead of implementing these security measures, and the risk of side-channel attacks targeting cryptographic keys.

7.7.3 Future research directions. To enhance the resilience against known attacks discussed above, developing adaptive and context-aware MFA approaches – designed to ensure authentication factors and keys remain unpredictable and challenging for attackers to replicate – presents a promising direction for future research.

7.8 Adversarial assumption

Accurately assessing capabilities of an adversary is crucial for determining the appropriate mitigation strategies needed to counter specific security threats. However, this has been identified as a weakness in many of the MFA protocols analyzed.

7.8.1 Mitigation strategies. As highlighted by Zahednejad et al. [91], assuming a weak adversary with limited access to information may not accurately reflect real-world threats. Therefore, it is crucial to adopt a more realistic approach and acknowledge the adversary's full potential. This ensures that security mitigation strategies are effectively designed and implemented to successfully counter potential attacks.

7.8.2 Potential challenges. The main challenge in making realistic adversarial assumptions lies in the significant resources and effort required to accurately understand and model an adversary's capabilities within a specific context and scenario.

7.8.3 Future research directions. To overcome challenges in adversarial modeling, the development of adaptive, dynamic, and context-aware threat modeling could offer a promising direction for future research.

8 Conclusion

To raise the security bar against imposers, several MFA protocols have been recently developed for various applications and use-cases. However, most of these protocols are vulnerable to a wide range of cyber risks. This is often due to security flaws that appear in these protocols due to lack of careful consideration when designing or implementing them.

In this work, we reviewed and analyzed several MFA protocols to identify potential security flaws in the protocols. In particular, we systematically analyzed the design and construction of the protocols using a set of security evaluation criteria we employed. Our evaluation uncovered several security flaws in most of the MFA protocols reviewed. In particular, we performed a deeper analysis and discussion on ten selected MFA protocols. Consequently, we provided a detailed discussion of the respective security flaws identified. We also devised relevant mitigation strategies for each of the security flaws identified. Additionally, we discussed the potential challenges associated with each of the devised mitigation strategies. We also highlighted future research direction in the security of MFA protocols.

Our evaluation revealed multiple security flaws in most of the MFA protocols reviewed. Specifically, we conducted a deeper analysis of ten selected MFA protocols and provided a detailed discussion of the identified security flaws. In addition, we devised relevant mitigation strategies for each flaw and examined the potential challenges associated with their implementation. Furthermore, we highlighted future research directions for enhancing the security of MFA protocols.

Just Accepted

We believe that the consolidated information would provide a single reference point for researchers to be aware of the potential security issues that require attention and apply the necessary mitigation strategies when designing MFA protocols. It is also worth noting the importance of performance alongside its security. The performance of the MFA protocol should not be overlooked. Complementing it with an efficient performance will improve the adoption rate of the secure MFA protocol, thus enhancing the overall security.

To further strengthen the design and implementation of an MFA protocol, a security-by-design approach [73] would be considered. In the future, this work can be further extended by employing a formal analysis of the protocols. Emerging security concerns, such as the security risk posed by the advent of quantum computing, can also be included as additional evaluation criteria.

Acknowledgment

This research is supported by the National Research Foundation, Singapore and Infocomm Media Development Authority under its Trust Tech Funding Initiative (DTC-T2FI-CFP-0002). Any opinions, findings and conclusions or recommendations expressed in this material are those of the author(s) and do not reflect the views of National Research Foundation, Singapore and Infocomm Media Development Authority.

References

[1] 2019. NOTICE ON CYBER HYGIENE. https://www.mas.gov.sg/-/media/mas/notices/pdf/psn06-notice-on-cyber-hygiene.pdf
[2] 2022. Multi-factor Authentication Fact Sheet. https://www.cisa.gov/sites/default/files/publications/MFA-Fact-Sheet-Jan22-508.pdf
[3] 2023. Importance of Using Secure Multi-Factor Authentication Methods — csa.gov.sg. https://www.csa.gov.sg/alerts-advisories/Advisories/2023/ad-2023-006. [Accessed 22-08-2023].
[4] Nuku Abiew, Maxwell Dorgbefu Jnr, and Samuel Banning. 2020. Design and Implementation of Cost Effective Multi-factor Authentication Framework for ATM Systems. *Asian Journal of Research in Computer Science* (04 2020), 7–20. https://doi.org/10.9734/ajrcos/2020/v5i330135
[5] AlsharifHasan Mohamad Aburbeian and Manuel Fernández-Veiga. 2024. Secure Internet Financial Transactions: A Framework Integrating Multi-Factor Authentication and Machine Learning. *AI* 5, 1 (2024), 177–194.
[6] Fardin Ahmadi, Sonia Garg, Gaurav Gupta, Preety Baglat, Puja Thakur, and Syed Zahra. 2021. Multi-factor Biometric Authentication Approach for Fog Computing to ensure Security Perspective. https://doi.org/10.1109/INDIACom51348.2021.00031
[7] Alawi Al-Saggaf, Tarek Sheltami, Hoda Alkhzaimi, and Gamil Ahmed. 2022. Lightweight Two-Factor-Based User Authentication Protocol for IoT-Enabled Healthcare Ecosystem in Quantum Computing. *Arabian Journal for Science and Engineering* 48 (09 2022), 1–11.
[8] Ahmed Aleroud and Lina Zhou. 2017. Phishing Environments, Techniques, and Countermeasures: A Survey. *Computers & Security* 68 (04 2017). https://doi.org/10.1016/j.cose.2017.04.006
[9] Zeeshan Ali, Sajid Hussain, Rana Rehman, Asmaa Munshi, Misbah Liaqat, Neeraj Kumar, and Shehzad Chaudhry. 2020. ITSSAKA-MS: An improved three-factor symmetric-key based secure AKA scheme for multi-server environments. *IEEE Access* PP (06 2020), 1–1.
[10] Mohammed Alkatheiri, Sajid Saleem, Mohammed Alqarni, Ahmad Aseeri, Sajjad Chauhdary, and Yu Zhuang. 2022. A Lightweight Authentication Scheme for a Network of Unmanned Aerial Vehicles (UAVs) by Using Physical Unclonable Functions. *Electronics* 11 (09 2022), 2921.
[11] Mwaheb S Almadani, Suhair Alotaibi, Hada Alsobhi, Omar K Hussain, and Farookh Khadeer Hussain. 2023. Blockchain-based multi-factor authentication: A systematic literature review. *Internet of Things* (2023), 100844.
[12] Sabrina Amft, Sandra Höltervennhoff, Nicolas Huaman, Alexander Krause, Lucy Simko, Yasemin Acar, and Sascha Fahl. 2023. "We've Disabled MFA for You": An Evaluation of the Security and Usability of Multi-Factor Authentication Recovery Deployments. In *Proceedings of the 2023 ACM SIGSAC Conference on Computer and Communications Security* (Copenhagen, Denmark) *(CCS '23)*. Association for Computing Machinery, New York, NY, USA, 3138–3152. https://doi.org/10.1145/3576915.3623180
[13] Ruhul Amin, SK Islam, P. Vijayakumar, Khurram Khan, and Victor Chang. 2018. A robust and efficient bilinear pairing based mutual authentication and session key verification over insecure communication. *Multimedia Tools and Applications* 77 (2018). https://doi.org/10.1007/s11042-017-4996-z
[14] Mourade Azrour, Jamal Mabrouki, and Rajasekhar Chaganti. 2021. New Efficient and Secured Authentication Protocol for Remote Healthcare Systems in Cloud-IoT. *Security and Communication Networks* 2021 (05 2021), 1–12. https://doi.org/10.1155/2021/5546334
[15] Mohammadreza Barkadehi, Mehrbaksh Nilashi, Othman Ibrahim, Ali Fardi, and Sarminah Samad. 2018. Authentication Systems: A Literature Review and Classification. *Telematics and Informatics* 35 (03 2018). https://doi.org/10.1016/j.tele.2018.03.018
[16] Elaine Barker. 2022. NIST Special Publication 800-57 Part 1, Revision 5: Recommendation for Key Management Part 1 – General. https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-57pt1r5.pdf.

Just Accepted

[17] Elaine Barker and William C. Barker. 2019. NIST Special Publication 800-57 Part 2, Revision 1: Recommendation for Key Management Part 2 – Best Practices for Key Management Organizations. https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-57pt2r1.pdf.
[18] Elaine Barker and Quynh Dang. 2015. NIST Special Publication 800-57 Part 3, Revision 1: Recommendation for Key Management Part 3 – Application-Specific Key Management Guidance. https://nvlpubs.nist.gov/nistpubs/specialpublications/nist.sp.800-57pt3r1.pdf.
[19] S. Barman, H. P. H. Shum, S. Chattopadhyay, and D. Samanta. 2019. A secure authentication protocol for multi-server-based E-healthcare using a fuzzy commitment scheme. *IEEE Access* 7 (2019), 12557–12574.
[20] Bruno Blanchet et al. 2016. Modeling and verifying security protocols with the applied pi calculus and ProVerif. *Foundations and Trends® in Privacy and Security* 1, 1-2 (2016), 1–135.
[21] Mariem Bouchaala, Cherif Ghazel, and Leila Saidane. 2022. Enhancing security and efficiency in cloud computing authentication and key agreement scheme based on smart card. *The Journal of Supercomputing* 78 (01 2022), 1–26. https://doi.org/10.1007/s11227-021-03857-7
[22] Michael Burrows, Martin Abadi, and Roger Needham. 1990. A logic of authentication. *ACM Trans. Comput. Syst.* 8, 1 (February 1990), 18–36.
[23] Aldar Chan, Jun Wen, Jianying Zhou, and Joseph Teo. 2016. Scalable Two-Factor Authentication Using Historical Data, Vol. 9878. 91–110.
[24] A. C.-F. Chan, J. W. Wong, J. Zhou, and J. Teo. 2016. Scalable two-factor authentication using historical data. In *Proc. ESORICS*, Vol. 9878. Springer, 91–110.
[25] Rui Chen, Yongcong Mou, and Min Zhang. 2022. A novel three-factor authentication scheme with high security for multi-server environments. *Wireless Personal Communications* 124, 1 (2022), 763–781.
[26] Xiao Chen, BaoCheng Wang, and Haibin Li. 2024. A privacy-preserving multi-factor authentication scheme for cloud-assisted IoMT with post-quantum security. *Journal of Information Security and Applications* 81 (2024), 103708.
[27] Zigang Chen, Zhiquan Cheng, Wenjun Luo, Jin Ao, Yuhong Liu, Kai Sheng, and Long Chen. 2023. FSMFA: Efficient firmware-secure multi-factor authentication protocol for IoT devices. *Internet of Things* 21 (04 2023), 100685. https://doi.org/10.1016/j.iot.2023.100685
[28] Ivaylo Chenchev. 2023. Framework for Multi-factor Authentication with Dynamically Generated Passwords. In *Future of Information and Communication Conference*. Springer, 563–576.
[29] Cue. 2023. Scams to watch out for in 2023. The Straits Times. https://www.straitstimes.com/business/invest/scams-to-watch-out-for-in-2023.
[30] Aleksandar Sandro Cvetković, Vesna Radojčić, and Saša Adamović. 2021. Multi-factor Authentication for the Internet of Things. *ZBORNIK RADOVA UNIVERZITETA SINERGIJA* 22. https://doi.org/10.7251/ZRSNG2101013C
[31] Default. 2023. Importance of using secure multi-factor authentication methods. https://www.csa.gov.sg/alerts-advisories/Advisories/2023/ad-2023-006. Accessed on: [insert date].
[32] Parwinder Dhillon and Sheetal Kalra. 2018. Multi-factor user authentication scheme for IoT-based healthcare services. *Journal of Reliable Intelligent Environments* 4 (2018). https://doi.org/10.1007/s40860-018-0062-5
[33] Prabakaran Durairaj and Shyamala Ramachandran. 2021. Multi-Factor Authentication for Secured Financial Transactions in Cloud Environment. *Computers, Materials and Continua* 70 (09 2021), 1781–1798. https://doi.org/10.32604/cmc.2022.019591
[34] Blaise Gassend, Dwaine Clarke, Marten van Dijk, and Srinivas Devadas. 2002. Silicon physical random functions. In *Proceedings of the 9th ACM conference on Computer and communications security (CCS '02)*. Association for Computing Machinery, New York, NY, USA, 148–160. https://doi.org/10.1145/586110.586132
[35] GDPR.eu. 2020. General Data Protection Regulation (GDPR) compliance guidelines. https://gdpr.eu/.
[36] Amir Hossein Ghafouri Mirsaraei, Ali Barati, and Hamid Barati. 2022. A secure three-factor authentication scheme for IoT environments. *J. Parallel and Distrib. Comput.* 169 (11 2022), 87–105. https://doi.org/10.1016/j.jpdc.2022.06.011
[37] Conor Gilsenan, Fuzail Shakir, Noura Alomar, and Serge Egelman. 2023. Security and Privacy Failures in Popular {2FA} Apps. In *32nd USENIX Security Symposium (USENIX Security 23)*. 2079–2096.
[38] Yiran Han, Hua Guo, Jianwei Liu, Brou Bernard Ehui, Yapeng Wu, and Sijia Li. 2024. An Enhanced Multifactor Authentication and Key Agreement Protocol in Industrial Internet of Things. *IEEE Internet of Things Journal* 11, 9 (2024), 16243–16254. https://doi.org/10.1109/JIOT.2024.3355228
[39] Md Hassan and Zarina Shukur. 2021. A Secure Multi Factor User Authentication Framework for Electronic Payment System. 1–6. https://doi.org/10.1109/CRC50527.2021.9392564
[40] The White House. 2021. Executive Order on Improving the Nation's Cybersecurity. https://www.whitehouse.gov/briefing-room/presidential-actions/2021/05/12/executive-order-on-improving-the-nations-cybersecurity/
[41] Charlie Jacomme and Steve Kremer. 2021. An extensive formal analysis of multi-factor authentication protocols. *ACM Transactions on Privacy and Security (TOPS)* 24, 2 (2021), 1–34.
[42] Chenglu Jin, Zheng Yang, Tao Xiang, Sridhar Adepu, and Jianying Zhou. 2023. HMACCE: Establishing Authenticated and Confidential Channel From Historical Data for Industrial Internet of Things. *IEEE Transactions on Information Forensics and Security* 18 (2023), 1080–1094. https://doi.org/10.1109/TIFS.2023.3234873

Just Accepted

[43] Mohammed Jubur, PrakashPrakash Shrestha, and Nitesh Saxena. 2025. An In-Depth Analysis of Password Managers and Two-Factor Authentication Tools. *Comput. Surveys* (2025).
[44] Nikolaos Karapanos, Claudio Marforio, Claudio Soriente, and Srdjan Capkun. 2015. {Sound-Proof}: Usable {Two-Factor} authentication based on ambient sound. In *24th USENIX security symposium (USENIX security 15)*. 483–498.
[45] Haqi Khalid, Shaiful Hashim, Sharifah Mumtazah, Fazirulhisyam Hashim, and Muhammad Chaudhary. 2021. SELAMAT: A New Secure and Lightweight Multi-Factor Authentication Scheme for Cross-Platform Industrial IoT Systems. *Sensors* 21 (02 2021), 1428.
[46] Keunok Kim, Jihyeon Ryu, Youngsook Lee, and Dongho Won. 2023. An Improved Lightweight User Authentication Scheme for the Internet of Medical Things. *Sensors* 23 (2023), 1122. https://doi.org/10.3390/s23031122
[47] Ravi Kumar, Samayveer Singh, and Pradeep Singh. 2023. A secure and efficient computation based multifactor authentication scheme for Intelligent IoT-enabled WSNs. *Computers and Electrical Engineering* 105 (01 2023), 108495. https://doi.org/10.1016/j.compeleceng.2022.108495
[48] Yaw-Wen Kuo, Cho-Long Li, Jheng-Han Jhang, and Sam Lin. 2018. Design of a wireless sensor network-based IoT platform for wide area and heterogeneous applications. *IEEE Sensors Journal* 18, 12 (2018), 5187–5197.
[49] DeokKyu Kwon, Sungjin Yu, JoonYoung Lee, SeungHwan Son, and YoungHo Park. 2021. WSN-SLAP: Secure and Lightweight Mutual Authentication Protocol for Wireless Sensor Networks. *Sensors* 21 (2021), 936. https://doi.org/10.3390/s21030936
[50] HakJun Lee, Dongwoo Kang, Youngsook Lee, and Dongho Won. 2021. Secure Three-Factor Anonymous User Authentication Scheme for Cloud Computing Environment. *Wireless Communications and Mobile Computing* 2021 (07 2021). https://doi.org/10.1155/2021/2098530
[51] Joonyoung Lee, Sungjin Yu, Myeonghyun Kim, Youngho Park, and Ashok Kumar Das. 2020. On the Design of Secure and Efficient Three-Factor Authentication Protocol Using Honey List for Wireless Sensor Networks. *IEEE Access* PP (06 2020), 1–1. https://doi.org/10.1109/ACCESS.2020.3000790
[52] Zengpeng Li, Zheng Yang, Pawel Szalachowski, and Jianying Zhou. 2020. Building Low-Interactivity Multi-Factor Authenticated Key Exchange for Industrial Internet-of-Things. *IEEE Internet of Things Journal* PP (07 2020), 1–1. https://doi.org/10.1109/JIOT.2020.3008773
[53] Zhiqiang Ma and Jun He. 2022. Outsider key compromise impersonation attack on a multi-factor authenticated key exchange protocol. In *International Conference on Applied Cryptography and Network Security*. Springer, 320–337.
[54] Ahmed Tanvir Mahdad and Nitesh Saxena. 2023. SoK: A Comprehensive Evaluation of 2FA-based Schemes in the Face of Active Concurrent Attacks from User Terminal. In *Proceedings of the 16th ACM Conference on Security and Privacy in Wireless and Mobile Networks*. 175–186.
[55] Bimal Meher and Ruhul Amin. 2022. A location-based multi-factor authentication scheme for mobile devices. *International Journal of Ad Hoc and Ubiquitous Computing* 41 (04 2022). https://doi.org/10.1504/IJAHUC.2022.10050034
[56] Reem Melki, Hassan Noura, and Ali Chehab. 2020. Lightweight Multi-Factor Mutual Authentication Protocol for IoT Devices. *International Journal of Information Security* 19 (2020). https://doi.org/10.1007/s10207-019-00484-5
[57] Ali Hameed Yassir Mohammed, Rudzidatul Akmam Dziyauddin, and Liza Abdul Latiff. 2023. Current multi-factor of authentication: Approaches, requirements, attacks and challenges. *International Journal of Advanced Computer Science and Applications* 14, 1 (2023).
[58] NIST CSRC. 2024. NIST Cryptographic Standards and Guidelines. https://csrc.nist.gov/Projects/Cryptographic-Standards-and-Guidelines.
[59] JiHyeon Oh, Sungjin Yu, JoonYoung Lee, SeungHwan Son, MyeongHyun Kim, and YoungHo Park. 2021. A Secure and Lightweight Authentication Protocol for IoT-Based Smart Homes. *Sensors* 21 (02 2021), 1488. https://doi.org/10.3390/s21041488
[60] Aleksandr Ometov, Sergey Bezzateev, Niko Mäkitalo, Sergey Andreev, Tommi Mikkonen, and Yevgeni Koucheryavy. 2018. Multi-factor authentication: A survey. *Cryptography* 2, 1 (2018), 1.
[61] Soufiene Othman. 2023. Secure and Lightweight Authentication Protocol for Privacy Preserving Communications in Smart City Applications. (03 2023). https://doi.org/10.3390/su15065346
[62] Can Ozkan and Kemal Bicakci. 2020. Security Analysis of Mobile Authenticator Applications. 18–30. https://doi.org/10.1109/ISCTURKEY51113.2020.9308020
[63] Matteo Paier, Roberto Van Eeden, and Marino Miculan. 2024. Formal Analysis of Multi-Factor Authentication Schemes in Digital Identity Cards. In *International Conference on Software Engineering and Formal Methods*. Springer, 423–440.
[64] Fabien A. P. Petitcolas. 2011. *Kerckhoffs' Principle*. Springer US, Boston, MA, 675–675. https://doi.org/10.1007/978-1-4419-5906-5_487
[65] Ariel Rabkin. 2008. Personal Knowledge Questions for Fallback Authentication: Security Questions in the Era of Facebook. *In SOUPS 2008: Proceedings of the 4th Symposium on Usable Privacy and Security, vol 23*, 13–23. https://doi.org/10.1145/1408664.1408667
[66] Farva Rafique, Mohammad S Obaidat, Khalid Mahmood, Muhammad Faizan Ayub, Javed Ferzund, and Shehzad Ashraf Chaudhry. 2022. An efficient and provably secure certificateless protocol for industrial Internet of Things. *IEEE Transactions on Industrial Informatics* 18, 11 (2022), 8039–8046.
[67] Mohammad Sabeeh and Ali adil Yassin. 2022. Privacy-preserving multi-factor authentication and role-based access control scheme for the E-healthcare system. *Bulletin of Electrical Engineering and Informatics* 11 (08 2022), 2131–2141. https://doi.org/10.11591/eei.v11i4.3658
[68] D. Sadhukhan, S. Ray, G.P. Biswas, M.K. Khan, and M. Dasgupta. 2020. A lightweight remote user authentication scheme for IoT communication using elliptic curve cryptography. *The Journal of Supercomputing* 77 (2020), 1114–1151.

Just Accepted

[69] Mangal Sain, Oloviddin Normurodov, Chen Hong, and Kueh Hui. 2022. A Survey on the Security in Cyber Physical System with Multi-Factor Authentication. 1–8. https://doi.org/10.23919/ICACT53585.2022.9728892
[70] James Saxon and Nick Feamster. 2022. GPS-based geolocation of consumer IP addresses. In *International Conference on Passive and Active Network Measurement*. Springer, 122–151.
[71] Salman Shamshad, Muhammad Faizan Ayub, Khalid Mahmood, Saru Kumari, Shehzad Chaudhry, and Chien-Ming Chen. 2021. An enhanced scheme for mutual authentication for healthcare services. *Digital Communications and Networks* 8 (07 2021). https://doi.org/10.1016/j.dcan.2021.07.002
[72] Geeta Sharma and Sheetal Kalra. 2018. A Lightweight User Authentication Scheme for Cloud-IoT Based Healthcare Services. *Iranian Journal of Science and Technology, Transactions of Electrical Engineering* 43 (10 2018), 1–18. https://doi.org/10.1007/s40998-018-0146-5
[73] CSA Singapore. 2017. Security-by-Design Framework Version 1.0. https://www.csa.gov.sg/docs/default-source/csa/documents/legislation_supplementary_references/security_by_design_framework.pdf?sfvrsn=560b9ff3_0.
[74] Singapore Statutes Online. 2021. PERSONAL DATA PROTECTION ACT 2012 (2020 REVISED EDITION). https://sso.agc.gov.sg/Act/PDPA2012.
[75] Federico Sinigaglia, Roberto Carbone, Gabriele Costa, and Nicola Zannone. 2020. A survey on multi-factor authentication for online banking in the wild. *Computers & Security* 95 (2020), 101745.
[76] Tance Suleski, Mohiuddin Ahmed, Wencheng Yang, and Eugene Wang. 2023. A review of multi-factor authentication in the Internet of Healthcare Things. *Digital health* 9 (2023), 20552076231177144.
[77] Google Team. [n. d.]. https://support.google.com/accounts/answer/1066447
[78] Tran Phuong Thao, Mhd Irvan, Ryosuke Kobayashi, Rie Shigetomi Yamaguchi, and Toshiyuki Nakata. 2020. Self-enhancing gps-based authentication using corresponding address. (2020), 333–344.
[79] Sun Tzu. 2010. *The Art of War*. Capstone Publishing.
[80] Ertan Uysal and Mete Akgün. 2023. P/Key: PUF based second factor authentication. *PloS one* 18 (2023), e0280181. https://doi.org/10.1371/journal.pone.0280181
[81] D Venkatasubramanian, Saumya Goyal, G. Ezhilarasan, Yogesh K. Sharma, V.J. Vijayalakshmi, and Prateek Garg. 2024. Evaluating the Effectiveness of Multi-Factor Authentication for Preventing Cyber Attacks. In *2024 15th International Conference on Computing Communication and Networking Technologies (ICCCNT)*. 1–6. https://doi.org/10.1109/ICCCNT61001.2024.10724922
[82] R Vinoth, Lazarus Jegatha Deborah, Pandi Vijayakumar, and Neeraj Kumar. 2020. Secure multifactor authenticated key agreement scheme for industrial IoT. *IEEE Internet of Things Journal* 8, 5 (2020), 3801–3811.
[83] Qingxuan Wang and Ding Wang. 2023. Understanding Failures in Security Proofs of Multi-Factor Authentication for Mobile Devices. *IEEE Transactions on Information Forensics and Security* 18 (2023), 597–612. https://doi.org/10.1109/TIFS.2022.3227753
[84] Xiong Wang, Yuan Teng, Yaping Chi, and Hongbo Hu. 2022. A Robust and Anonymous Three-Factor Authentication Scheme Based ECC for Smart Home Environments. *Symmetry* 14 (11 2022), 2394. https://doi.org/10.3390/sym14112394
[85] Wikimedia Foundation. 2023. Mutual authentication. https://en.wikipedia.org/wiki/Mutual_authentication.
[86] Joseph Williamson and Kevin Curran. 2021. Best Practice in Multi-factor Authentication. *Semiconductor Science and Information Devices* 3 (05 2021).
[87] Anhao Xiang and Jun Zheng. 2020. A Situation-Aware Scheme for Efficient Device Authentication in Smart Grid-Enabled Home Area Networks. (06 2020). https://doi.org/10.3390/electronics9060989
[88] Jia Xiaoying, Debiao He, Neeraj Kumar, and Kim-Kwang Raymond Choo. 2019. Authenticated key agreement scheme for fog-driven IoT healthcare system. *Wireless Networks* 25 (11 2019). https://doi.org/10.1007/s11276-018-1759-3
[89] Bailin Xie, Qi Li, and Hao Qian. 2022. *Weak Password Scanning System for Penetration Testing*. 120–130. https://doi.org/10.1007/978-3-030-94029-4_9
[90] Jinghai Yi and Yunhua Wen. 2023. An Improved Data Backup Scheme Based on Multi-Factor Authentication. In *2023 IEEE 9th Intl Conference on Big Data Security on Cloud (BigDataSecurity), IEEE Intl Conference on High Performance and Smart Computing, (HPSC) and IEEE Intl Conference on Intelligent Data and Security (IDS)*. 187–197. https://doi.org/10.1109/BigDataSecurity-HPSC-IDS58521.2023.00041
[91] Behnam Zahednejad, Huang Teng, Saeed Kosari, and Ren Xiaojun. 2023. A Lightweight, Secure Big Data-Based Authentication and Key-Agreement Scheme for IoT with Revocability. *International Journal of Intelligent Systems* 2023 (04 2023), 1–19. https://doi.org/10.1155/2023/9731239

Just Accepted

Table A.1. Description of notations

Notation	Description	Notation	Description
AKA	Authenticated key agreement	mk	Master key (pre-shared key)
AVISPA	Automated validation of Internet security protocols and applications	mod	Modulo operation
BAN	Burrows–Abadi–Needham	MP	Medical professional
BD	Biometric Data	NI	No information
BMFAaaS	Blockchain-based multi-factor authentication-as-a-service	OC	Other criteria
CAF	Client authentication factor	OTP	One-time password
CMK	Client master key	PFS	Perfect forward secrecy
CPS	Cyber-physical systems	PIN	Personal identification number
CSI	Concurrent session injection	PQFC	Post-quantum fuzzy commitment
d_i	Data i	PUF	Physically unclonable functions
EC	Evaluation criteria	PW	Password
ECC	Elliptic curve cryptography	$r1/r2$	Random number
DoS	Denial of service	ROR	Real-Or-Random
GPS	Global positioning system	SA	Strong adversary
HD	Historical data	SAF	Server authentication factor
HDT	Historical data tags	SC	Smart card
HIoT	Healthcare IoT	SCI	Server compromise impersonation
HOTP	HMAC-based one-time password	SFA	Singe-factor authentication
$h(\cdot)$	Hash function (hashing)	SID/sid	Session ID
IoT	Internet of things	SSID	Secret SID
IMSI	International mobile subscriber identity	SK	Session key
K	Tag generation key	SMK	Server master key
KCI	Key compromise impersonation	TGK	Tag generation key
KSSTI	Known session-specific temporary information	T_i	Tag i
LSK	Long-term shared key	TLS	Transport layer security
M	Message	TOTP	Time-based one-time password
M2M	Machine-to-Machine	UID	User ID
MAKE	Multi-factor authenticated key exchange	WA	Weak adversary
MFA	Multi-factor authentication	WSN	Wireless sensor networks
MFCC	Mel frequency cepstral coefficient	XOR	Exclusive OR
MITM	Man-in-the-middle	$\oplus$	XOR operation

Just Accepted

A Supplementary Materials

A.1 Notations and acronyms

A.2 Comparative performance analysis of MFA protocols

Although most MFA protocols primarily focus on their security guarantee, their performance overhead (or the security-efficiency tradeoff) should not be neglected. In fact, some protocols employ too many authentication factors without considering the penalty in performance. However, performance is usually equally critical as security, especially in resource and real-time constrained systems, such as IoT and CPS. Therefore, it is essential to assess the performance of MFA protocols as well. To do such assessment, researchers use different types of performance metrics. The most commonly used ones are computation cost (i.e., the amount of resources required to execute the authentication protocol), communication bits (i.e., the amount of data required to be transmitted between entities), communication passes (i.e., the number of messages exchanged between the client and the server to complete the authentication process), authentication time (i.e., the time taken to complete the authentication process), and the storage cost (i.e., the storage size required to complete the authentication process). Therefore, we also used these metrics to perform a comparative performance analysis of the ten protocols

investigated. The overall performance analysis is summarized in Table A.2. We believe that this helps future researchers to easily obtain the performance information of the protocols in a single reference point.

Table A.2. Performance comparison of the 10 MFA protocols

Protocol	Computation Cost	Communication Bits	Communication Passes	Time Taken (ms)	Storage Required
Protocol 1 [42] (π_{woFS})	$326T_h + 1T_{aed}$	3992	2	22.39	-
Protocol 1 [42] (π_{FS})	$328T_h + 4T_{ecc} + 1T_{aed}$	4748	3	115.549#	-
Protocol 2 [36]	$18T_h + 14T_x + 2T_{fe} + 2T_{ecc}$	1024	1	198.21	-
Protocol 3 [91]	$4T_{me} + (2z + 3)T_m + (2z)T_a + (2z + 26)T_h$	2720	4	11.28	3.4GB + 252B
Protocol 4 [47]	$26T_h + 2T_{ed}$	2000	3	-	-
Protocol 5 [14]	$17T_h$#	1312*	3	-	-
Protocol 6 [9]	$15T_h + 1T_{fe} + 3T_{ed}$	2144	2	8.9385	-
Protocol 7 [80]	$4T_h + 2T_p$	640	1	-	404 GB
Protocol 8 [68]	$5T_h + 2T_{ecc} + 8T_{ed}$	1600	3	80.6	480 bits
Protocol 9 [32]	$1T_{me} + 7T_h$	448*	1	-	-
Protocol 10 [56]	$10T_h + 10T_x + 1T_{fe}$	896	2	-	-

Description of notations: T_h: hash operation, T_{ecc}: ECC multiplication, T_{ed}: symmetric encryption decryption, T_{aed}: SLHAE encryption and decryption, T_x: XOR operation, T_{fe}: fuzzy extraction operation, T_p: PUF computation, T_{me}: modular exponential operation, T_a: addition operation, T_m: multiplication operation, # : XOR operations ignored, * : Estimated value, -: no information provided.

Received 25 July 2024; revised 29 January 2025; accepted 2 April 2025

Just Accepted